INDEPENDENT SECURITY ASSESSMENT / 27 OCTOBER 2026

XITA Direct-BLS Interchain

Final audit and launch readiness assessment

NO-GO

Unresolved node accounting boundary.
Security, recovery and production gates remain open.

Audit ID: **XITA-DBLS-2026-10-27-v3.0.0**

29 current risk entries. 43 preserved historical occurrences.
Independent Phase A frozen before historical reassessment.

Authorized frozen source

xgr-network/xgr-interchain / main
ffc24139738bcb25ab516e5d3242f258a75fcfb8

xgr-network/xgr-node / XGR3.0
4d341a08baa604c7871e10af8c7c2e2406f4d032

OpenAI GPT-6 Astra - AI-assisted independent source and evidence assessment commissioned by the project owner. This is not a human audit-firm attestation.

Complete publication-safe English report. Detailed executable reproductions are preserved separately under access control. No production transaction, deployment or configuration change was performed.

Contents

1. Executive summary 3

2. Snapshot, scope and method 4

3. Architecture and trust boundaries 6

4. Contract and protocol assessment 7

5. Node, finality and ordinary consensus 8

6. Relayer, fees, sponsorship and wallet recovery 9

7. Current consolidated findings 10

8. Residual architecture risks and dedicated H-01 reassessment 22

9. Deployment, build and production verification 24

10. Executed verification and limitations 26

11. Reassessment of both historical audits 28

12. Launch decision and remediation gates 58

13. Artifact integrity and archival 59

Reading guide: section7 consolidates current risks; section8 reassesses H-01; section11 preserves every historical identity. Section12 defines the gates. Test success is never equated with installation or unconditional launch approval.

1. Executive summary

The frozen system is not ready for a controlled public launch. The decisive blocker is F-01: an independently identified native execution/accounting boundary in the node. Completed isolated checks observed unfunded native credits and source tracing reached the real block-processing path. A complete malicious consensus proposal was not constructed or broadcast, and installed-validator exposure is not proven. Nevertheless, launch approval cannot assume supply integrity until the admissible system-transaction and fee-accounting rules are resolved and the corrected installed binaries are verified.

This conclusion does not depend on keeping historical H-01 at High. The current source substantially improves external evidence verification: XGR source messages use locally committed IBFT state, while Base and Arbitrum require complete matching witnesses from two differently identified operators. H-01 is now assessed **Medium residual architectural risk**, with high potential impact if two counted sources are correlated or compromised. Provider/upstream independence and operating acceptance remain incomplete; no global conflict-veto behavior is claimed.

The bridge contracts exhibit meaningful current-set, exact-message, replay, route and escrow controls. No permissionless principal mint, collateral theft, forged BLS authorization or replay double payment was identified in the examined contract paths. That is a bounded result, not a proof of absence. Native-chain execution correctness, current-quorum availability, the adopted L2 safe policy and underlying-token behavior remain independent prerequisites.

The audit also reproduced important service and recovery defects: a restricted SQL writer can report ready while positive sponsored quotes fail; an interrupted sponsor reservation can strand the sender nonce; a pending grant RPC failure can block healthy chains; and a successful Mailbox delivery can conceal a backed but unclaimed native payout. The background delivery queue still suffers the historical N-11 failure even though the wallet-pagination part was corrected.

Current inventory	Critical	High	Medium	Low	Informational
29 entries	0	1	17	9	2

Launch priorities	P0	P1	P2
Current entries	1	18	10

These counts represent deduplicated current vulnerability, architecture, operations and assurance entries. They include one previously documented accepted architecture risk. They are not all unprivileged asset-loss exploits. Historical counts remain unchanged: 17 entries on 24 October and 26 unresolved entries on 25 October, with date-qualified IDs preserved. Of the 43 historical occurrences, 12 are VERIFIED for their original code condition, one is FIXED_IN_CODE and 30 remain OPEN with the independently assigned current severity. No historical row is represented as installed-production RELEASED.

Evidence that materially improves confidence

- All 1,353 source blobs in the two downloaded snapshots matched the connected GitHub trees: 589 Interchain and 764 node blobs.
- All 57 sampled deployed runtime hashes matched their deployment receipts at pinned canonical blocks. Fresh compilation found no unexplained instruction differences after narrowly separating compiler immutables and Solidity metadata digests.

- Eight route configurations passed inbound identity checks; wrong route IDs and source routers were rejected. All three registries had three members and a threshold of two.
- The release binary matched its published SHA-256 and embedded source revision. This proves download/release correspondence, not host installation.
- Regression and isolated failure-path tests were executed. Known fixture failures and unavailable browser checks are reported explicitly.

Decision-relevant limitations

The audit had no authenticated access to validator executable files, service environments, production PostgreSQL roles, private-key custody or live wallet acceptance sessions. No paid transfer, adversarial production traffic, deployment, asset movement or production configuration change occurred. An automated security filter stopped deeper exploit-oriented node reproduction. The original 25 October PDF and confidential ZIP were not recovered; that historical inventory uses the public register and the retrieved prior final response, with current-source reassessment performed independently.

2. Snapshot, scope and method

2.1 Authorized source scope

Repository	Branch	Frozen commit	Git tree
xgr-network/xgr-interchain	main	ffc24139738bcb25ab516e5d3242f258a75fcfb8	3654eff1b4015ccee78ead91cc9a6617cf08e762
xgr-network/xgr-node	XGR3.0	4d341a08baa604c7871e10af8c7c2e2406f4d032	cc24e44aeecc7dafabe445da18242bb7fea07330

The connected GitHub metadata record was captured at **2026-10-27T07:14:49.792Z**. These exact snapshots are the source authority for the assessment. Production read-only observations cover XGRChain (1643), Base (8453) and Arbitrum (42161). Source review covers the active contracts, Direct-BLS runtime, observer and recovery paths, wallets, indexer, fees, sponsorship, admin tools, deployment records and release controls. A documentation-only publication branch does not extend the audited source scope.

The repository continued changing after the freeze. The documentation PR preserves the then-current main branch while clearly identifying the older audited source. Later code is not silently included in this opinion, and merging this report does not certify every subsequent commit.

2.2 Three consecutive phases

Phase A examined current implementation and executed independent checks before reading either prior audit or remediation narrative. Contract, node, sponsorship and integration workstreams recorded their findings independently. The combined record was frozen at **2026-10-27T07:23:07.946971Z**, SHA-256 **2a50051a01d73f36dcd01faed86709947395ed4474ae93578b4802d2fa85be32**. The component hashes and timestamp are retained in `phase-a-freeze.json`; the exact text is `phase-a-findings.md`.

Phase B then reconstructed both historical inventories, examined corrective merge ancestry and current paths, and checked targeted regressions or stated the absence of such a check. Findings first recognized in this phase are labelled B in the current inventory; they were not inserted into Phase A retrospectively. In particular, the final M-04 assessment includes an unbounded submission transport found while tracing the historical shutdown condition. The bounded read-side client does not cover that separate path.

Phase C combines source defects, implemented mitigations, architecture assumptions, actual tests and production limitations into exactly one launch decision. This is a new full assessment, not a delta-only endorsement of merged patches.

2.3 Evidence and status semantics

Label	Meaning in this report
OPEN	A relevant failure condition, residual risk or verification obligation remains. Current severity may differ from historical severity.
FIXED_IN_CODE	Current source contains the correction; the required direct closure test or deployment proof is incomplete.
VERIFIED	The original condition has been independently checked against current source and the stated local evidence. This does not mean every related risk is resolved.
RELEASED	Verified correction and actual target rollout are independently established. Publication of a downloadable binary alone is insufficient.
ACCEPTED_RISK	An explicit, bounded pre-existing architecture decision is preserved with its assumptions and review trigger. This is not a new risk acceptance on the owner's behalf.
NOT_APPLICABLE	A documented condition is disproven or genuinely superseded; no historical row is silently erased.

P0 blocks launch. P1 is required before scaling and can allow, at most, an explicitly restricted controlled operation once P0 is closed. P2 is strengthening or maintenance that does not independently block the current deployment. Severity describes security/operational impact and prerequisites; priority describes the launch obligation. An admin promotion flaw can be Low while still requiring correction before another deployment.

Every factual result below has an evidence path, immutable source reference or primary external source. The public ZIP inventories exact file sizes and hashes. Statements about absent full exploit demonstrations, incomplete rollout evidence and unsupported browser execution are part of the findings, not footnotes to be disregarded.

3. Architecture and trust boundaries

3.1 Principal and message flow

A source wallet calls the canonical gateway, directly or through the optional signed-quote Execution Gateway. Principal is locked or burned by its registered router; the validator fee and source message are committed atomically. Independent validators verify the exact source operation, produce message-specific BLS votes and aggregate the current destination-set threshold. A destination wallet or permissionless caller submits the authenticated message to the Mailbox, which verifies its ISM and routes execution to the registered asset router. The receiving router releases collateral/native value or mints the registered synthetic asset.

For a spoke-to-spoke transfer, XGRChain is the required hub. The normal core sequence is TX1 source lock/burn, TX2 delivery on XGRChain, TX3 onward lock/burn and TX4 final delivery. A one-hop journey uses TX1/TX2. Token allowance transactions, when needed, are additional user authorizations. There is no assertion that every wallet experiences exactly two or four total prompts.

The optional fee service and gas sponsor control their service keys and treasury, not the authenticated router principal. A service failure can impair convenience or gas availability without creating a unilateral principal-sweep capability. Manual recovery still needs valid source evidence, current-set authorization, live destination execution and transaction gas. Permanent loss of quorum cannot be solved by a privileged administrator in the ownerless registries.

3.2 Authority boundaries

Boundary	Current control	Remaining assumption or gap
Source observation to local BLS vote	Local committed XGR evidence; complete two-operator external witnesses; synchronization checks	External provider/upstream trust; installed source identity; F-05
Individual votes to destination execution	Active set/key checks, threshold bitmap, aggregate verification and exact message/domain binding	Current quorum availability and independently controlled keys
Message delivery to asset availability	Router/route binding, escrow reserve accounting and replay protection	Deferred native claims require separate beneficiary action; F-09
Fee quote to sponsor obligation	EIP-712 payer/route/chain binding and atomic durable quote/commitment creation	Restricted-role readiness, reservation abuse and lifecycle gaps
Index/database to wallet UI	Rebuildable canonical observations and explicit unknown states	Discovery completeness, queue progress and exact user intent binding
Optional worker to validator host	Separate execution loops, bounded read RPC and some message admission	Aggregate resource limits and unbounded submission RPC; F-03/F-29

UI labels, database rows, public transaction hints and health responses never substitute for protocol authorization. Distinct wallet addresses or public keys do not prove distinct operators or physically independent key custody.

4. Contract and protocol assessment

The contract review examined 21 production Solidity files, the relevant inherited behavior and all 15 repository Solidity test files. The 16-suite unmodified run contained 103 tests: 102 passed and one expected-revert fixture failed. A separate isolated setup confirmed the intended factory guard. Actual EIP-2537 single-key, aggregate, changed-message and infinity-rejection vectors passed; mocked cryptography was used only where a test intentionally isolated policy or payout behavior.

4.1 Direct-BLS authorization

The fixed-width transfer payload binds source chain/domain, route, source registry/gateway/router/Mailbox, message identifier, source height, fee, destination router, destination ISM, destination registry and current destination validator set. The ISM rejects an obsolete set before signature verification and checks the exact message Keccak and router identities. Current-set re-attestation can recover pending messages without another source lock.

The registry enforces proof of possession and key consistency, rejects duplicate active keys and malformed/noncanonical bitmap selections, and computes the threshold as ceil(2n/3). The live three-member set therefore requires two signatures. Transfer quorum is distinct from ordinary stake-weighted chain consensus. Membership transition signatures have a narrower domain than transfer messages: the registry address omission remains the explicitly bounded F-11 architecture risk.

Relevant immutable source: XITADirectProtocol, XITADirectBLSISM, ValidatorRegistry.

4.2 Escrow, routing and replay

Router outbound paths require the canonical gateway. Inbound execution requires the configured Mailbox and enrolled source router; the router recomputes its expected reverse route from the registered asset and exact router pair. Direct spoke-to-spoke route construction is rejected. Synthetic issuance begins at zero and is reachable only through authenticated handling. Native and collateral transfer paths charge principal once; collateral intake verifies the exact balance increase rather than silently accepting an immediate fee-on-transfer mismatch.

Mailbox replay protection and transaction atomicity prevent duplicate successful handling and roll back a failed authentication/handler call. Native deferred delivery deliberately returns success while reserving a beneficiary claim; it remains fully backed, but Mailbox completion does not prove a wallet balance increase. F-09 concerns this distinction and the missing user claim path.

The eight FeeVaults observed at pinned blocks cover allocated-minus-claimed liabilities. Transfer-time fee allocation is constant-time; epoch snapshots and paginated withdrawal retain historical membership entitlements. An independent fuzz property covered 257 cases with 40 validator epochs each. This is useful contract accounting evidence, not a proof of all-time cross-chain supply conservation.

4.3 Administration and compiler boundary

The six asset routers have zero owners; the optional Execution Gateway administrator has no principal-sweep authority. All three observed recovery owners differ from service wallets, although inherited ownership transitions can collapse that separation (F-10). Deployment promotion finality and lock recovery retain the historical Low issues F-22/F-23.

The source build used solc 0.8.24 with viaIR/Yul optimization. The official SOL-2026-7 advisory covers this optimizer range; it was fixed in 0.8.38. No XITA-specific miscompilation was established. Source/runtime correspondence cannot exclude a compiler defect shared by both builds. Existing-artifact exclusion requires a targeted same-version fix comparison or suitable equivalence

proof; generic recompilation is not definitive. Official advisory and known-bugs register, consulted 27 October 2026.

5. Node, finality and ordinary consensus

5.1 Signing path and finality

Automatic observation, on-demand requests and peer hints reach the common signing function. It checks synchronization before collecting evidence and immediately before signing, rereads current destination membership and delivery state, and persists a local vote through a file write and atomic rename before gossip. Power-loss durability of that vote-write path is not established: unlike retry admission, it does not explicitly sync the file and directory (`interchain/runtime/iln_checkpoint.go:115-129`). Completed-quorum import verifies the aggregate/current-set/domain boundary and does not create a bypass for new local source votes.

External witnesses each use one endpoint for the entire operation. Success requires a valid receipt, canonical block, exact gateway operation, bound Mailbox dispatch, route snapshot and validator fee. Evidence from different providers is not spliced into one witness. Valid unrelated dispatches in the same receipt are supported; duplicate matching identities are rejected. Node PR71 corrects historical N-02 and its current regression passed.

Base and Arbitrum use the native `safe` head for bridge source authorization, with canonical numeric block/hash checks and no fallback to `latest`. XGR uses locally committed IBFT evidence. These policies are not equivalent to final Ethereum settlement. Base distinguishes safe derivation from finalized L1 data; Arbitrum documents that safe blocks can still change during a significant L1 reorganization. Base derivation and Arbitrum finality guidance, consulted 27 October 2026.

5.2 Observer and restart behavior

The shared source observer reduces repeated discovery reads and keeps source-local progress. Failed operation processing is journaled with file/directory durability before cursor advancement, and retry work re-enters full verification. This materially improves original N-01. It does not establish fair service under every backlog, isolation from corrupt/full journals, retention across all set-rotation transitions or complete log discovery. F-04, F-20 and F-21 preserve those separate residual conditions.

The Arbitrum on-chain activation getter uses a parent-chain height, whereas RPC receipt blockNumber uses an L2 height. The observed differences were reconciled against receipt l1BlockNumber. Current node discovery uses configured RPC-native deployment receipt heights, including 517836903 for the Arbitrum source registry, and contains migration handling for the older coordinate mismatch. The integration indexer likewise obtains gateway deployment height from verified receipts. This difference is not reported as a current defect.

5.3 Consensus accounting and resource isolation

The optional Interchain worker is not inserted into the synchronous IBFT proposal-verification hook. It still shares process, host resources and shutdown lifecycle. Race-detector success does not demonstrate bounded latency under hostile workload, and the ordinary read-client timeout does not bound separate membership/governance submission transports. F-03 and F-29 remain distinct operational weaknesses.

F-01/F-02 examine underlying native execution and gas accounting rather than BLS message authentication. The High finding is supported by static tracing and already completed local accounting observations, with a privileged proposer-path prerequisite and an explicit end-to-end verification limit. There was no production proposal, validator-key compromise or live asset movement. The security interruption ended further exploit-oriented construction; the report does not recast an unexecuted test as passed.

6. Relayer, fees, sponsorship and wallet recovery

6.1 Signed fee quotes and durable obligations

EIP-712 binds the payer, gateway, source execution domain, route, amount, recipient, first and final destination, onward identity, bridge value, service fee, nonce and issue time. The live maximum quote lifetime is 90 seconds on all three Execution Gateways. Nonces are payer-scoped, consumed atomically and reverted with failed execution. All three observed quote digests matched independent EIP-712 computation.

The quote service persists tax evidence, immutable intent and grant commitments atomically before returning a usable signed quote. Aggregate admission accounts for outstanding promises, payout gas and current spendable treasury under sorted chain locks shared with grant reservation. Incoming principal is not treated as sponsor gas liquidity. Historical N-07 is VERIFIED for its original missing-aggregate-accounting condition; actual multi-process production concurrency remains untested, and F-06 is a newly introduced restricted-role integration problem.

Current payout receipt checks require adopted native finality and canonical hash agreement, both immediately and during reconciliation. N-08's original premature permanent confirmation is VERIFIED in code-level checks. Expired unused quote release is a separate path: it uses a five-minute post-expiry eligibility grace and source nonce evidence, but F-16 documents the single-provider/no-canonical-reread boundary. Five minutes is not a guaranteed release deadline.

6.2 Two-hop sponsorship

The original circular funding dependency N-05 is corrected: all three immutable positive gas grants can become eligible immediately after the paid TX1 evidence, before TX2 or TX3. The current candidate SQL joins a real promise before its limit, so older positive microfee transfers without grants do not displace owed work (N-12). An actual PostgreSQL-engine scenario confirmed both properties. These original closures coexist with F-07/F-08/F-19: interruption, receipt failures or external early delivery can still leave obligations unresolved.

Unpaid public quote admission still consumes finite promised capacity. Rate limits, quote lifetime and finalized-unused reconciliation mitigate historical N-06 without eliminating repeated unpaid occupation. This mainly affects new sponsored quotes; no direct proof is claimed that unpaid commitments are counted inside the separate payout reservation query for already paid grants.

6.3 Wallet and recovery claims

The browser uses an EIP-1193 request interface and performs account, chain and nonce checks around wallet submission. This is broader than a hard-coded single-wallet authorization gate, but it is not a tested compatibility certification for all browser wallets, mobile connectors, hardware devices or account-abstraction models. Two browser smoke tests were blocked by missing Chromium; no real wallet session was used.

Recovery uses canonical source receipts, current-set proof construction and on-chain duplicate/onward-parent guards. Bounded local storage holds public transaction locators per account, not authority. Reconnect/reload retention now preserves known broadcasts and separates them from verified journeys (N-10). Destination proof calldata still lacks an independent browser-level selected-message binding (F-13), and native claims still require the missing distinct presentation/recovery path (F-09).

The indexer correctly accepts finality-qualified negative delivery observations, closing M-02's original sticky-success condition. It remains exposed to dense-window stalls and unknown-route worklist

starvation. PR310 explicitly improved wallet pagination only; it does not establish closure of background N-11. UI status, backend progress and on-chain principal availability must remain separate evidence categories.

7. Current consolidated findings

ID	Severity	Priority	Disposition	Finding
F-01	High	P0	OPEN	Native system-transaction accounting and proposal validation
F-02	Medium	P1	OPEN	Transaction-original storage and refund accounting
F-03	Medium	P1	OPEN	Expensive gossip work lacks complete admission bounds
F-04	Medium	P1	OPEN	Shared observer retry fairness and failure isolation
F-05	Medium	P1	OPEN	External source witnesses retain correlated-provider trust
F-06	Medium	P1	OPEN	Quote-writer readiness misses required SQL privileges
F-07	Medium	P1	OPEN	Sponsor reservation can strand the sender nonce after interruption
F-08	Medium	P1	OPEN	One grant RPC failure can block all-chain sponsorship
F-09	Medium	P1	OPEN	Mailbox completion can conceal a pending native-principal claim
F-10	Low	P2	OPEN	Authorized ownership transfer can collapse service/admin separation
F-11	Medium	P1	ACCEPTED_RISK	Membership authorizations omit the exact registry deployment
F-12	Low	P1	OPEN	Minimum validator committee size remains an operating rule
F-13	Low	P2	OPEN	Wallet proof calldata is not fully bound to selected intent
F-14	Low	P2	OPEN	Regression fixtures and CI discovery drift from the current product
F-15	Medium	P1	OPEN	Production sponsorship and installation readiness remain unproven
F-16	Medium	P1	OPEN	Expiry-release evidence trusts one RPC without a canonical reread
F-17	Medium	P1	OPEN	Unpaid quote reservations can still occupy sponsorship capacity
F-18	Low	P2	OPEN	Conservative daily-limit accounting can count a liability twice
F-19	Medium	P1	OPEN	Paid grant lifecycle can remain unresolved after early delivery or shutdown
F-20	Medium	P1	OPEN	Pending recovery work can be removed before durable replacement
F-21	Medium	P1	OPEN	Successful incomplete discovery responses can advance durable cursors
F-22	Low	P2	OPEN	Admin deployment evidence uses confirmation depth as finality
F-23	Low	P2	OPEN	Orphaned deployment locks require careful manual recovery

ID	Severity	Priority	Disposition	Finding
F-24	Low	P2	OPEN	Fee-tax backfill omits required verified event identity
F-25	Low	P2	OPEN	Dense event windows lack adaptive progress
F-26	Medium	P1	OPEN	Unknown route rows can starve background delivery refresh
F-27	Informational	P2	OPEN	Published CLI version fields are empty despite valid embedded VCS data
F-28	Informational	P2	OPEN	Compiler advisory applicability remains an assurance gap
F-29	Medium	P1	OPEN	Membership and governance submission RPC remains unbounded

The following entries consolidate duplicates across dates and workstreams. Historical IDs and their original severity are preserved separately in section 11. “Passed” in a failure-reproduction test means the failure was observed as asserted, not that it was repaired.

F-01 - Native system-transaction accounting and proposal validation

High / P0 / OPEN. Discovery phase A. Cross-reference: NODE-A-01.

Native system-transaction execution and subsequent fee/refund accounting do not maintain one consistent funding rule. Proposal validation does not establish a sufficiently narrow admissible system-transaction set or an explicit deterministic base-fee equality check.

Impact and prerequisites. A proposer-controlled block path is the relevant prerequisite. If reachable in installed consensus participants, unfunded native credits threaten supply integrity and the economic backing of native bridge assets. This is separate from external RPC evidence trust.

Evidence. Frozen node state/executor.go, types/transaction.go, consensus/ibft/fork/hooks.go and block/header validation were traced. Completed isolated accounting checks observed unfunded credits, including the real ProcessBlock path. Confidential evidence retains the local outputs; no full malicious consensus proposal was constructed or broadcast.

Required action. Constrain system transactions at block validation, make non-fee-bearing semantics consistent through execution, verify deterministic header fees, and add supply-conservation/rejection regressions. Publish a corrected release and attest every installed validator binary before approval.

Verification limit. The automated security filter stopped deeper exploit-oriented reproduction. Installed-node exposure and complete end-to-end consensus acceptance are not established. Existing Interchain tests passing does not resolve this accounting boundary.

F-02 - Transaction-original storage and refund accounting

Medium / P1 / OPEN. Discovery phase A. Cross-reference: NODE-A-02.

The transaction-original storage baseline is not consistently replaced between transactions, while refund subtraction permits unsigned underflow.

Impact and prerequisites. Multiple storage updates across transactions can be charged or refunded incorrectly. The execution refund cap limits the demonstrated effect; this issue alone does not establish unlimited refunds or arbitrary minting.

Evidence. Node state/txn.go:221-287,449-457,480-488,550-584 and state/executor.go:479-483. A completed isolated refund-state check observed wrapping; full multi-transaction network reproduction was not performed.

Required action. Maintain transaction-local original-slot state, enforce refund arithmetic invariants and verify cross-transaction storage-gas cases under the correct fork rules. Coordinate any consensus-semantic correction.

Verification limit. Source tracing and a local arithmetic check support the finding; no live exploit or complete EVM transaction sequence was verified.

F-03 - Expensive gossip work lacks complete admission bounds

Medium / P1 / OPEN. Discovery phase A. Cross-reference: NODE-A-03; 24:M-05; 25:M-05.

Checkpoint-vote and quorum-hint messages can reach full source verification before adequate member/signature admission and global bounded concurrency control. Governance-proposal admission also lacks global count, disk and maximum-future-lease bounds.

Impact and prerequisites. Adversarial peer traffic can consume RPC, CPU and worker capacity shared with the validator process. Optional-worker separation from synchronous IBFT hooks does not prove host resource isolation.

Evidence. Node interchain/runtime/worker.go:830-880, iln_checkpoint.go:168-201, iln_quorum_request.go:211-238, governance.go:201-240 and network/gossip.go:108-122; bounded local seam observation and standard/race tests.

Required action. Add cheap admissibility checks, per-peer and global limits, bounded concurrency, in-flight deduplication and fair service before remote reads. Bound accepted governance count, disk use and maximum future lease. Preserve complete source verification before signing; demonstrate consensus continuity under controlled load.

Verification limit. No production flood or demonstrated IBFT outage. Transport deadlines and existing selected-message throttles mitigate individual requests.

F-04 - Shared observer retry fairness and failure isolation

Medium / P1 / OPEN. Discovery phase A. Cross-reference: NODE-A-04; 25:N-01 residual.

Durable retries improve poisoned-operation isolation, but a fixed route iteration order consumes a bounded source budget. Capacity and corrupt-record errors still affect the shared source group.

Impact and prerequisites. Later routes can wait indefinitely behind persistent earlier backlogs; queue pressure can stop source-wide discovery. Work is retained rather than silently discarded.

Evidence. Node interchain/runtime/iln_observer_retry.go:17-25,74-105,141-199 and iln_observer_worker.go:128-162,180-210. A bounded scheduler check reproduced lack of service to a later route; existing durability tests passed.

Required action. Rotate retry service fairly, quarantine corruption without losing original evidence, expose backlog age/capacity, and verify a healthy late route progresses under sustained earlier failures.

Verification limit. The current small route set was not observed stalled. The starvation scenario exercises a larger/backlogged scheduler; no disk power-loss or production outage test.

F-05 - External source witnesses retain correlated-provider trust

Medium / P1 / OPEN. Discovery phase A. Cross-reference: NODE-A-05; 24:H-01; 25:H-01.

External signing requires two differently labelled operators with complete matching evidence. The first matching pair wins; an earlier disagreement is not a global veto, and labels cannot prove independent upstream infrastructure.

Impact and prerequisites. Two colluding or correlated data sources can give honest validators a consistent false view. Multiple BLS keys do not remove that shared evidence dependency. One faulty independently counted witness alone is insufficient; a physical upstream can nevertheless correlate more than one label. Duplicated URLs with the same label do not add votes.

Evidence. Node config.go, evm/rpc_evidence_quorum.go and tests, evm/finality.go and tests, runtime/iln_direct_signing.go. Existing and bounded injected-reader checks; live reachability of configured endpoints; primary provider/finality documentation.

Required action. Record actual provider and fallback-pair independence, monitor disagreements, preserve fail-closed per-witness checks and explicitly accept the L2 safe model. Reassess if operational evidence shows two counted operators share a controlling upstream.

Verification limit. Medium is a current residual architecture assessment, not a claim of independent upstream attestation or formal risk acceptance. Correlated fabricated real RPC receipts and a live authorization based on fabricated source evidence were not constructed. This is not a claimed cryptographic BLS break.

F-06 - Quote-writer readiness misses required SQL privileges

Medium / P1 / OPEN. Discovery phase A. Cross-reference: S-A01.

Current restricted-role migrations omit SELECT on xita_transfer_operations, although the aggregate quote-capacity query now joins it. The readiness query does not test this dependency.

Impact and prerequisites. A deployment using the documented dedicated quote writer can advertise readiness while every quote promising at least one positive sponsor grant fails. The transaction rolls back; this is availability failure, not an unsigned or partially journaled promise.

Evidence. Managed-relay tax-evidence.mjs:130-145, server.mjs:92-101, SQL migrations010/011. Exact migrations and real saveQuoteEvidence under PostgreSQL/WASM reproduced readiness true then error42501 and zero committed evidence rows.

Required action. Grant only required reads through reviewed migrations; readiness must exercise the complete restricted-role operation or validate every dependency, including resolution evidence.

Verification limit. A consolidated installed writer may already have permission. Production database roles were not accessible; live sponsorship unavailability is not attributed to this defect without host evidence.

F-07 - Sponsor reservation can strand the sender nonce after interruption

Medium / P1 / OPEN. Discovery phase A. Cross-reference: S-A02.

The grant reservation commits before signed transaction bytes or a durable hash exist. Reconciliation covers submitted rows with hashes, leaving pre-broadcast or uncertain reserved states without a complete recovery path.

Impact and prerequisites. An interrupted grant can retain the unique sponsor nonce and block later grants while the chain pending nonce remains unchanged. It also remains an outstanding financial promise.

Evidence. Managed-relay gas-sponsor.mjs:209-223,340-343. Exported-function fault injection and actual PostgreSQL reservation/uniqueness/reconciliation checks reproduced the wedge.

Required action. Durably journal exact signed transaction bytes and expected hash before broadcast; reconcile all lifecycle states, safely rebroadcast the same bytes and resolve uncertain outcomes without duplicate payment.

Verification limit. No live process crash or real sponsor transfer was induced. The current uniqueness guard prevents conflicting nonce reuse; do not remove it as a shortcut.

F-08 - One grant RPC failure can block all-chain sponsorship

Medium / P1 / OPEN. Discovery phase A. Cross-reference: S-A03.

One pending grant receipt error escapes the reconciliation loop, which is awaited before any new candidates. Oldest-only bounded windows also lack robust fairness.

Impact and prerequisites. An outage on one chain can stop healthy-chain payouts and delay owed grants. This is broader than an individual provider timeout.

Evidence. Managed-relay gas-sponsor.mjs:340-361,475-476. Offline injected503 on the first chain prevented examination of a healthy subsequent chain.

Required action. Isolate failures per grant and chain, bound work, apply backoff and rotate scheduling while retaining ambiguous liabilities. Demonstrate healthy-chain progress during another chain outage.

Verification limit. No production worker outage was generated; the live endpoint reports unavailable sponsorship but does not identify its cause.

F-09 - Mailbox completion can conceal a pending native-principal claim

Medium / P1 / OPEN. Discovery phase A. Cross-reference: C-A01; 25:N-09.

A valid native delivery that cannot pay the recipient within the router gas allowance records a backed pending claim and returns success. The UI equates Mailbox delivery with completed native payout and exposes no claim workflow.

Impact and prerequisites. The wallet can show completion while its native balance remains unchanged. A smart wallet able to call the claim method can redirect payout; an arbitrary contract without such an execution path cannot be assumed recoverable.

Evidence. XETAGuardedNativeWarpRouter.sol:25-38,68-85; transfer-status-flow.js:119-145; transfer-token-journey.js. Real Mailbox/router integration with explicitly mocked authentication reproduced backed pending funds; actual UI projection reproduced the misleading completion.

Required action. Index deferred delivery, show the claim balance separately, add beneficiary-authorized claim/recovery instructions and verify supported smart-wallet execution. Until then restrict supported native recipients and describe this limit accurately.

Verification limit. No BLS bypass or unbacked claim. The test uses mocked ISM only to isolate the delivery boundary; separate real EIP-2537 vectors passed.

F-10 - Authorized ownership transfer can collapse service/admin separation

Low / P2 / OPEN. Discovery phase A. Cross-reference: C-A02; 24:L-03; 25:L-03.

Constructor and service-wallet rotation checks enforce distinct roles, but inherited two-step ownership transfer can nominate and accept the current service wallet.

Impact and prerequisites. An authorized administrator can accidentally defeat the intended independent recovery authority. No unprivileged privilege escalation or principal sweep is present.

Evidence. XITAExecutionGateway.sol:130-155 and inherited ownership transitions; local two-step transition reproduced. Live roles are distinct on all three chains.

Required action. Enforce inequality at ownership nomination, acceptance and setServiceWallet, including pendingOwner. Recheck current roles at acceptance to cover both transition orders; retain independent recovery key custody.

Verification limit. Requires authorized owner action; current deployments do not exhibit collapsed roles.

F-11 - Membership authorizations omit the exact registry deployment

Medium / P1 / ACCEPTED_RISK. Discovery phase A. Cross-reference: C-A03; historical AR-01.

Membership payloads bind chain/domain, set, action, expiry and keys but not the registry address. Matching parallel deployments can accept the same valid transition.

Impact and prerequisites. Cross-instance membership replay is possible during overlapping equivalent deployments. Transfer authorizations separately bind the destination ISM and registry, so this is not a transfer-message replay.

Evidence. XGRInterchainValidatorRegistryV3.sol:376-460 and XITADirectProtocol.sol:42-49. An explicitly mocked verifier isolated the identical payload/state-machine behavior; current manifests pin one registry per chain.

Required action. Maintain the documented single-active-registry invariant. Reopen protocol domain design before overlapping migration or parallel registries; bind deployment identity in a deliberately versioned membership scheme if that invariant changes.

Verification limit. ACCEPTED_RISK refers to the pre-existing documented architectural decision, limited to its stated controls. No new blanket operator acceptance is invented. The audit cannot prove no unlisted parallel contract exists.

F-12 - Minimum validator committee size remains an operating rule

Low / P1 / OPEN. Discovery phase A. Cross-reference: C-A04.

The registry accepts a nonempty bootstrap and allows authorized reductions to one member; the correctly computed two-thirds quorum then becomes one signature.

Impact and prerequisites. An authorized configuration can reduce fault tolerance below the intended launch committee. This is a governance/operations condition, not an unprivileged quorum bypass.

Evidence. contracts/XGRInterchainValidatorRegistryV3.sol:122-135,306-335,630-631; isolated policy tests with mocked cryptography. All three observed registries have three members and threshold two, with identical ordered keys.

Required action. Monitor at least three independently operated active members and concentration, and verify current-set re-attestation continuity. Consider a protocol minimum only with an explicit governance/migration design.

Verification limit. Separate physical operators and retained key custody were not independently attested. A permanent loss of quorum has no administrator bypass.

F-13 - Wallet proof calldata is not fully bound to selected intent

Low / P2 / OPEN. Discovery phase A. Cross-reference: L-A01; 24:L-01; 25:L-01.

The browser and indexer validate metadata, destination, selector and zero value but do not independently hash the actual process message bytes against the selected transfer.

Impact and prerequisites. A compromised response may cause gas expenditure on another independently valid message. The destination still enforces cryptographic authentication; no forged mint or principal redirection is established.

Evidence. apps/web/transfer-actions.js:614-674; services/indexer/transfer-recovery.mjs:65-87; honest native-relayer construction separately binds the complete payload.

Required action. Decode and bind the actual authorization and message before wallet submission, including destination and selected message ID.

Verification limit. Static defense-in-depth finding; no malicious browser/mainnet transaction executed.

F-14 - Regression fixtures and CI discovery drift from the current product

Low / P2 / OPEN. Discovery phase A. Cross-reference: L-A02; C-A05; 24:I-01; 25:I-01.

A Solidity expected-revert is misplaced; old checker hook/chain assumptions and several UI/indexer assertions no longer match current behavior. Selected CI lists omit some discovered tests.

Impact and prerequisites. A passing selected pipeline does not establish a clean full regression baseline. The observed failures do not themselves demonstrate a factory bypass or incorrect current token mapping.

Evidence. Unmodified Solidity102/103, UI273/280 (five stale assertions and two missing-browser failures), indexer136/137. Corrected isolated factory setup passes. Existing compatibility checker conditions were statically inspected.

Required action. Repair expectations against current deployment/catalog facts, make test discovery explicit and run supported browser/wallet acceptance checks. Keep failed originals visible in evidence.

Verification limit. Two browser checks were not executable because Chromium was unavailable. Do not count them as product regressions or successful browser tests.

F-15 - Production sponsorship and installation readiness remain unproven

Medium / P1 / OPEN. Discovery phase A. Cross-reference: L-A03.

Live managed health reports sponsorship enabled but unavailable on all three chains. One public node reports a current version and healthy observer, but host-level binary/service/database attestations are absent.

Impact and prerequisites. A publicly advertised sponsored low-gas experience is not currently demonstrated operational. Self-funded users and authenticated principal recovery are separate paths; source fixes alone do not attest installation.

Evidence. Read-only live/observations.json and route-configuration.json; downloaded release digest and embedded source revision; current app.js/catalog exact hashes.

Required action. Restore and verify sponsored-service readiness or explicitly restrict the service to self-funded users. Obtain installed binary hashes, service revisions, restricted-role checks and real representative one-/two-hop acceptance evidence.

Verification limit. No specific source defect is asserted as the cause of live unavailability. F-01 remains an independent P0; disabling sponsorship cannot resolve it.

F-16 - Expiry-release evidence trusts one RPC without a canonical reread

Medium / P1 / OPEN. Discovery phase A. Cross-reference: Sponsorship residual O-01.

Expired unused quote capacity is released after chain-native finality-qualified nonce inspection through one configured provider, pinned by block number without a final canonical hash reread. Base/Arbitrum use finalized; XGR uses latest under the adopted committed-IBFT model.

Impact and prerequisites. A false or inconsistent source view can remove a real pending commitment from liability accounting and allow overcommitment of optional sponsor treasury.

Evidence. gas-sponsor.mjs:87-98,399-430 and tax-evidence.mjs:130-137; the exported expiry function accepted one head read and a numeric nonce read in an isolated check. The five-minute grace and native finality head are real mitigations.

Required action. Use complete canonical finalized evidence with post-read hash verification and an explicitly justified provider trust policy; retain ambiguous paid liabilities until safely resolved.

Verification limit. This does not grant Direct-BLS signing or access user principal. No real false provider or production insolvency was induced.

F-17 - Unpaid quote reservations can still occupy sponsorship capacity

Medium / P1 / OPEN. Discovery phase A. Cross-reference: Sponsorship residual O-02; 25:N-06.

Unauthenticated clients can reserve real sponsorship capacity with signed public quotes. Expiry reconciliation and rate limits shorten the window but do not prove wallet control or prevent repeated distributed occupation.

Impact and prerequisites. Legitimate users requesting new sponsored quotes can encounter unavailable capacity despite no attacker payment. This concerns quote admission, not proof that already paid grants are directly displaced by unpaid quotes. Limits and reconciliation mitigate occupation but do not establish a maximum holding time.

Evidence. Current quote rate limits, aggregate admission SQL, 90-second lifetime and five-minute post-expiry reconciliation reviewed; historical N-06 original long-lived daily occupation is materially reduced.

Required action. Distinguish provisional quote reservations from paid obligations, preserve safe accounting and add fair admission/abuse controls justified by measured service demand. Do not release ambiguous paid promises merely to regain capacity.

Verification limit. No distributed production denial-of-service test. Five minutes is an eligibility grace, not a guaranteed release deadline: finalized-head delay, RPC failure and bounded oldest-first processing can extend reservation indefinitely.

F-18 - Conservative daily-limit accounting can count a liability twice

Low / P2 / OPEN. Discovery phase A. Cross-reference: Sponsorship residual O-03.

Matching reserved, submitted and needs-review grants created within the rolling 24-hour window contribute both to daily spent accounting and to still-open commitment accounting.

Impact and prerequisites. The same in-flight obligation can conservatively consume capacity twice, reducing availability. The demonstrated direction is under-admission, not unbacked payment.

Evidence. tax-evidence.mjs:130-160 and sponsor-funding.mjs:42-52; static SQL/arithmetic review, not a separately executed database double-count test.

Required action. Define mutually exclusive economic states and reconcile daily spend with outstanding liabilities using one documented accounting model, retaining conservative treatment of uncertain outcomes.

Verification limit. No production utilization calculation was inspected; no solvency violation is claimed from this observation alone.

F-19 - Paid grant lifecycle can remain unresolved after early delivery or shutdown

Medium / P1 / OPEN. Discovery phase A. Cross-reference: Sponsorship residual O-04/O-05.

An unpaid upfront grant can become ineligible once an external valid delivery advances the transfer. Disabling sponsorship also stops processing while existing obligations remain.

Impact and prerequisites. Immutable paid promises can remain neither fulfilled nor safely resolved, occupying liability capacity and stranding the promised gas experience. Principal delivery may itself have succeeded.

Evidence. gas-sponsor.mjs:27-38,100-116,429-470 and server.mjs:401-427; stage eligibility and disabled-worker paths reviewed. Current UI gates normal progression on grants, but permissionless external delivery is an independent path.

Required action. Specify and implement durable obligation resolution across externally advanced transfers and service shutdown. Separate stopping new promises from draining or explicitly settling existing paid obligations.

Verification limit. No production unpaid-promise inventory was accessible. An operator switch is authorized behavior; the issue is the missing complete lifecycle for prior commitments.

F-20 - Pending recovery work can be removed before durable replacement

Medium / P1 / OPEN. Discovery phase B. Cross-reference: 25:N-03.

Set rotation or missing route handling can remove an old durable vote before replacement signing succeeds. Age-based cleanup also relies on assumed regeneration without a durable successor job.

Impact and prerequisites. A restart/rotation or temporary verification failure can lose automatic recovery work. A known source hash and available current quorum may still allow manual recovery.

Evidence. Node interchain/runtime/iln_checkpoint.go:383-400 and iln_storage.go:80-85; current static control-flow reassessment against the retrieved historical condition.

Required action. Retain original recovery evidence until a durable replacement or terminal authenticated delivery exists; journal transitions atomically and test restart/rotation failure boundaries.

Verification limit. No destructive restart/rotation experiment was performed. This was identified during Phase B and was not retroactively added to the frozen Phase A.

F-21 - Successful incomplete discovery responses can advance durable cursors

Medium / P1 / OPEN. Discovery phase B. Cross-reference: 25:N-04.

Discovery accepts the first successful single-provider log set; an incomplete but well-formed response can still be followed by cursor persistence.

Impact and prerequisites. Real operations or route notices can be missed by automatic discovery. Later signing still requires complete two-operator evidence; omission affects availability, not forged authorization.

Evidence. Node evm multi-Gateway scanner and runtime/iln_observer_worker.go:150-153; RouteAdded discovery has the same completeness trust boundary.

Required action. Add independent completeness checks, safe overlap/reconciliation or authenticated log-range mechanisms; preserve known-transaction recovery and alert on inconsistent sources.

Verification limit. A valid empty response cannot be declared false from syntax alone. No actual provider censorship or production missing transfer was demonstrated.

F-22 - Admin deployment evidence uses confirmation depth as finality

Low / P2 / OPEN. Discovery phase B. Cross-reference: 24:L-04; 25:L-04.

The deployment verifier can label confirmation-depth-qualified receipts as finalized without requiring the adopted native safe/IBFT policy.

Impact and prerequisites. A future deployment could be promoted on weaker evidence than its label promises. Current read-only canonical runtime checks provide separate assurance for the observed deployed contracts.

Evidence. services/admin/deployment-ledger.mjs:107-167; actual current verifier reproduced the historical acceptance boundary, recorded in evidence/contracts/admin-reassessment.json.

Required action. Apply shared chain-native finality and canonical receipt verification before deployment promotion; represent provisional depth separately from native finality.

Verification limit. No new deployment or real reorganization. Repair is required before a future deployment/promotion, even though this audit authorizes documentation only.

F-23 - Orphaned deployment locks require careful manual recovery

Low / P2 / OPEN. Discovery phase B. Cross-reference: 24:L-05; 25:L-05.

A process interruption can leave a file lock whose existence blocks later journal mutation even after a new process opens the intact journal.

Impact and prerequisites. Administrator deployment recovery can stop until the stale owner is safely established and the lock resolved. This does not itself cause duplicate broadcast or loss of the recorded intent.

Evidence. services/admin/deployment-intents.mjs:96-117,203-214; actual functions reproduced the stale-lock condition in an isolated directory (evidence/contracts/admin-reassessment.json).

Required action. Use robust process ownership or leases and a documented stale-lock recovery procedure that preserves journal and signed transaction identity. Time expiry alone must not evict a live writer.

Verification limit. No production journal was inspected or changed.

F-24 - Fee-tax backfill omits required verified event identity

Low / P2 / OPEN. Discovery phase B. Cross-reference: 24:L-06; 25:L-06.

backfillPaidFeeTax builds an event without messageId and txHash although storeVerifiedOperation requires both, even after successful upstream verification.

Impact and prerequisites. Eligible fee-evidence rows remain held and repeated sweeps roll back instead of completing reconciliation. Primary new ingestion is separate.

Evidence. services/indexer/transfer-index-worker.mjs:54-61,494-524; relocated historical local check against current functions reproduced verified0/held1 with BEGIN/ROLLBACK and no insert.

Required action. Carry the already verified row identities into the common store call; distinguish guard defects from temporarily missing evidence and add a successful-store regression.

Verification limit. No principal access or unauthorized payout; production tax records were not read.

F-25 - Dense event windows lack adaptive progress

Low / P2 / OPEN. Discovery phase B. Cross-reference: 24:L-07; 25:L-07.

Oversized route or grouped-source log windows are rejected and retried with the same range; increasing the shared cap does not provide adaptive splitting.

Impact and prerequisites. Legitimate dense history can stall automatic indexing. Manual known-hash recovery and announcements remain separate mitigations.

Evidence. Current transfer-index.mjs size guards and worker loops; two new isolated boundary tests reproduced unchanged windows. See evidence/indexer/historical-checks.tap.

Required action. Adaptively split block windows and fully process a single dense block under bounded resource control. Never truncate logs silently.

Verification limit. The new tests intentionally exercise the early size boundary, not full canonical validation of hundreds of real transfers. No live dense window was established.

F-26 - Unknown route rows can starve background delivery refresh

Medium / P1 / OPEN. Discovery phase B. Cross-reference: 25:N-11.

The background SQL limit is applied before resolving active routes; unknown rows skip both checking and scheduling timestamp advancement.

Impact and prerequisites. A sufficient old retired backlog can indefinitely hide healthy active-route delivery work. The wallet API sorting fix does not correct the background worker.

Evidence. transfer-index-worker.mjs:197-225; PR310 explicitly has partial scope and changes transfer-index-store.mjs only. Actual current migrations and PostgreSQL/WASM selection reproduced two sweeps with no active-route read.

Required action. Filter or schedule against active route identity before limiting, rotate/quarantine unknown work without losing history, and test background progress with a large retired backlog.

Verification limit. The production database backlog was not inspected; live eight-route coverage is a snapshot, not this adversarial acceptance test.

F-27 - Published CLI version fields are empty despite valid embedded VCS data

Informational / P2 / OPEN. Discovery phase B. Cross-reference: 24:I-02; 25:I-02.

The release workflow targets an obsolete versioning package path, so product Release version, Git branch, Commit hash and Build time fields remain empty.

Impact and prerequisites. Operational self-reporting is weaker and can confuse rollout checks. Independent download hashes and embedded Go VCS metadata still identify the published source revision.

Evidence. The downloaded v3.3.8 binary version command exited0 and returned all four fields as <none>; go version -m reports the exact frozen revision and vcs.modified=false.

Required action. Fix linker targets and require nonempty expected CLI fields plus matching embedded VCS revision in release gates; attest actual installed file hashes separately.

Verification limit. No daemon was launched; RPC self-reported version is not a disk-hash attestation. No signing or access-control failure is implied.

F-28 - Compiler advisory applicability remains an assurance gap

Informational / P2 / OPEN. Discovery phase B. Cross-reference: 24:I-03; 25:I-03.

Solidity0.8.24 with viaIR/Yul optimization lies within the affected configuration range of SOL-2026-7. Project-specific trigger/alias conditions have not been conclusively excluded.

Impact and prerequisites. Potential compiler exposure remains open as an assurance task, without a demonstrated XITA miscompilation or established principal-loss path.

Evidence. Official Solidity known-bugs advisory, foundry.toml settings and independent runtime/body comparison. Existing cryptographic and accounting tests are useful but not a compiler differential proof.

Required action. For existing artifacts compare the exact solc 0.8.24 build/settings with the targeted fix applied, or obtain a suitable equivalence proof. Source/IR review or an arbitrary newer compiler build alone is not definitive. Qualify a fixed compiler separately for future builds; investigate concrete differences before deciding on existing deployments.

Verification limit. No claim that all deployed contracts are exploitable; no broad redeployment is recommended solely from the advisory.

F-29 - Membership and governance submission RPC remains unbounded

Medium / P1 / OPEN. Discovery phase B. Cross-reference: 24:M-04; 25:M-04.

The read-side witness transport has deadlines and cancellation, but membership and governance submission paths construct a separate transaction relayer without the bounded client or worker shutdown context. Its receipt timeout setting controls polling intervals rather than individual I/O deadlines.

Impact and prerequisites. A hanging submission or preflight call can retain a worker indefinitely and block orderly shutdown. Shared source locks and outer polling add further lifecycle pressure; fixing ordinary read-side RPC does not close the whole original boundary.

Evidence. Node interchain/evm/client.go:400-448, interchain/evm/iln_governance_submit.go:130-153 and txrelayer/txrelayer.go:61-80,256-275; governance execution and membership submission are active callers. Static source/dependency tracing confirms the unbounded transport; existing transport cancellation tests exercise the bounded read client only.

Required action. Propagate bounded context-aware clients through every preflight, send and receipt wait; define transaction-uncertainty recovery and verify complete Worker.Close termination. Do not merely add an outer sleep timeout or automatically rebroadcast a different transaction.

Verification limit. No new transaction or hanging submission was executed. This Phase-B finding supersedes an initially considered Low classification for bounded shutdown delays; the final assessment is Medium/P1 OPEN.

8. Residual architecture risks and dedicated H-01 reassessment

8.1 Historical condition and implemented mitigation

Historical H-01 remains High in both original baselines. The24 October condition allowed common external RPC observations, including XGR source data, to become the shared trust root behind multiple validator signatures. Repeated queries and same-provider canonicality checks established consistency rather than provider honesty.

The current implementation changes the prerequisites materially. XGR evidence comes from locally committed synchronized state. External chains need two matching whole-operation witnesses with distinct configured operator IDs; duplicate URLs under one ID do not increase the count. Message bytes, message/transaction identity, log index, height, canonical hash, route snapshot, destination and fee all participate in equality. The common signing path applies this check before authorization. Relevant merged changes are node PR58, PR59 and PR62; section 11 records their exact merge hashes.

8.2 Provider identity is not infrastructure independence

Configured source	Endpoints and operator labels	What the evidence supports
Base	mainnet.base.org; gateway.tenderly.co/public/base; base-rpc.publicnode.com; base.drpc.org	Four configured labels, reachable identity/head reads. Separate endpoint names do not establish four independent upstream failure domains.
Arbitrum	arb1.arbitrum.io/rpc; arbitrum-one-rpc.publicnode.com; arbitrum.gateway.tenderly.co; arbitrum.drpc.org	Four configured labels, reachable identity/head reads; the same independence limitation applies.
XGRChain	Local committed native source evidence for signing	Public RPC was used by the auditor for observations, not substituted for the node's local signing authority.

Tenderly's published terms identify Tenderly, Inc. PublicNode's own site associates the service with Allnodes. Official network documentation identifies project RPC endpoints. These support distinct public-facing organizations/services, not independent cloud accounts, keys, source nodes or per-response provenance. Tenderly terms, PublicNode and Arbitrum provider reference, consulted 27 October 2026.

dRPC describes its service as a gateway across third-party partners and public nodes. Its documented load-balancing strategies include public-node pools. Therefore a counted dRPC response cannot automatically be assumed independent of another counted public endpoint. This is an inference about possible correlation, not evidence that a particular observed response used the same upstream. No response-level provider provenance or ownership attestation was available. dRPC overview and balancing strategies, consulted 27 October 2026.

No provider compromise, collusion or false production response was observed. Endpoint availability during a short probe does not establish future outage resilience, exclusive operation, or independent truth.

8.3 Adversarial evidence and exact fail-closed meaning

Scenario	Evidence and conclusion
One malicious/inconsistent witness with two matching honest observations	Bounded injected-reader behavior and existing quorum tests support accepting the matching pair; one faulty independently counted witness alone is insufficient.
Multiple URLs with one operator label	Existing integration tests reject counting the operator twice. Labels are configuration assertions.
Only one available operator	Existing integration tests fail closed; no quorum is fabricated.
Two conflicting observations	Existing integration tests fail to find a matching pair. This is not a global veto across all possible later witnesses.
Fee, route, message, receipt or canonical-hash mismatch	Existing comparison/finality tests passed; malformed or nonqualified observations do not become a matching complete witness.
Missing safe head or source above safe	Existing finality tests reject; no external-source latest fallback. A lagging head delays availability.
Two distinct labels returning matching false observations	Injected-reader combination checks demonstrate the trust assumption; no fabricated real receipt or live authorization based on fabricated source evidence was created.
Honest disagreement followed by a matching pair	Source control flow accepts the pair. The later dedicated local test was not executed after the safety interruption.
Timeouts and rate-limit/provider failures	Existing bounded-read failover/cooldown/cancellation tests passed. Full quorum-wide sustained-outage and production resource tests were not performed. Submission RPC has the distinct F-29 gap.

The implementation accepts the first matching pair. It does not require agreement from every configured provider, a majority of endpoints or an absence of earlier disagreement. “Reject conflicting evidence” must mean rejecting an individual incompatible witness combination, not an unimplemented universal conflict veto.

8.4 Current severity and acceptance threshold

Current H-01 residual severity: Medium, OPEN, P1. One independently counted external witness alone no longer satisfies the signing rule, and native XGR no longer depends on remote source evidence. External authorization requires two matching counted observations, but their physical upstreams have not been independently attested and may overlap. The remaining severe impact requires both counted observations to be false, through collusion, compromise or common upstream dependence. No such control was demonstrated. This supports Medium as a conditional architecture assessment rather than mechanically retaining historical High.

The assessment is not a claim that true upstream independence has been proven. Its controlled-launch conditions are documented operational diversity for every viable fallback pair, fail-closed verification on the installed release, disagreement/availability monitoring, and explicit risk-owner acceptance of the external witness and L2 safe assumptions. If two counted services are shown to share one controlling data source, the likelihood assessment must be reopened. The audit does not mark this risk newly ACCEPTED_RISK without that owner record.

A separate light client or self-hosted full node is not declared mandatory merely because the witness model has residual trust. Stronger authenticated source verification is a possible response if the

project's desired guarantee exceeds the reviewed model or independent failure domains cannot be established. No new centralized custody or validator route-admission gate is proposed.

8.5 Other retained architecture constraints

Membership signatures rely on the previously documented single-active-registry invariant (F-11). Arbitrary underlying tokens can rebase, pause, blacklist, upgrade or otherwise impair redemption after initial exact-debit checks; this is asset-specific issuer risk. Raw units and token decimals require exact handling, and passing six-decimal accounting cases does not validate every token class. Ownerless contracts do not guarantee liveness after permanent quorum loss. Off-chain services provide discovery and convenience, while on-chain evidence remains authoritative.

9. Deployment, build and production verification

9.1 Pinned live state

Chain	Chain ID	Pinned block	Canonical block hash
XGRChain	1643	12176701	0x82eecc381fb46fac5c9ff2c4b3b9aa12c140da889cbf0d8d3072ac71835da5d5
Base	8453	53148028	0xf2ba5663a19fd2133367a40516d73ab9192472987b91debed7cbd2a8ed881d95
Arbitrum	42161	518669953	0xc3f4426f2c9b05259e8b3b3435a942ff6ea56fca57a35f2f62a5ffffc4f1f5f5

The initial successful probe ran from 07:17:51.860Z to 07:18:10.139Z. Supplementary reads used the same pinned heights and reread unchanged canonical hashes. The first attempt without the audit environment's required proxy failed; it is retained as an environment/setup failure, not a production outage.

All 57 unique runtimes (21 XGR, 18 Base, 18 Arbitrum) matched receipt Keccak-256 hashes. Fresh compiled lengths matched all 57. Forty-five instances differed only in trailing IPFS metadata digests after declared immutables were separated; twelve additionally contained metadata digests embedded in child creation data. No unexplained instruction differences remained. This is not byte-for-byte compiler metadata reproduction. Getter/receipt checks supplement excluded immutable values; unexposed constructor-time values without independently decoded inputs remain limited.

Supplementary verification produced 424 getter/balance observations: 393 matching expected comparisons, zero mismatches and 31 descriptive values. Separate additional checks read six validator-set encodings, verified three EIP-712 quote digests and reconciled three Arbitrum activation getters against canonical creation receipts. All eight inbound routes accepted the correct binding and rejected wrong route IDs/routers. All six router owners are zero. All eight FeeVault balances cover observed allocated-minus-claimed obligations.

Registered asset	Direction set	Verified routes
XGR	XGRChain to/from Base and Arbitrum	4
ARB	XGRChain to/from Base and Arbitrum	4

All three validator registries reported set 1, three members, threshold 2 and matching ordered public keys. This confirms configured on-chain membership, not independent private-key control. The

Execution Gateway owner was 0x2f1048cf4c55bcafc0846a72c5bcb86a5b947b40 and service wallet 0xf0dcd6aad6de2057c7e49e7d294b3736504d4316 on all three chains; distinct addresses do not prove separate key storage.

The sampled XGR native router held 215 XGR, while synthetic supplies were 130 on Arbitrum and 85 on Base; pending native claims were zero. ARB collateral and corresponding synthetic supplies were zero. These are consistent asynchronous snapshots, not an all-time or in-flight-message supply proof.

9.2 Source, published release and installation

Evidence level	Actual result	Limit
GitHub source	Two exact branch SHAs and all blob hashes matched	Later source changes are outside this freeze
Published node release	v3.3.8 points to frozen node SHA; downloaded binary digest matches asset/checksum metadata	Not a reproducible rebuild or installed-host proof
Embedded build data	Go 1.23.12; frozen VCS revision; vcs.modified=false	Embedded metadata is a release claim, separately corroborated by downloaded digest
CLI product version	Four version fields are empty in the published binary	I-02/F-27 remains open despite correct Go VCS data
Public node behavior	Self-reports v3.3.8 and healthy caught-up eight-route observer	One endpoint cannot attest every signing validator or successful live quorum recovery
Public frontend	app.js and catalog.json exactly match frozen source hashes	Other modules and all service installations not comprehensively attested
Managed sponsorship	Enabled and wallet-aware, but unavailable on all three chains	No production cause attribution; no paid empty-gas acceptance journey

The downloaded Linux release binary is 73,021,839 bytes; SHA-256 **95fd72cc72b942d206b130ff4ef63df83d2d161a99d092cd68b9b240c6be9617**. The exact published commit is 4d341a08baa604c7871e10af8c7c2e2406f4d032. Release v3.3.8.

Final verification corrects a toolchain detail in the immutable Phase A notes: the downloaded release embeds **Go 1.23.12**. The local test toolchain was Go 1.23.11, and the public RPC client string reported Go 1.23.11. These are separate observations; their mismatch reinforces that a public version string cannot establish installation of the downloaded release. The original Phase A bytes remain preserved with this explicit correction.

Live managed health returned `paidQuoteReady=true` but `sponsorship.available=false`, reason `sponsor-reserves-or-worker-not-ready`. The health endpoint reports `proofBuilder=installed`. This does not independently attest the executable's identity, successful execution or current-quorum formation. The observed complete index coverage 8/8 is not eight completed end-to-end wallet journeys. No live role/secret audit, service process attestation, sustained resource test or installed binary hash capture was available.

10. Executed verification and limitations

Area	Actual result	Meaning and limit	Evidence inside public ZIP
Node existing suite	127 passed /127	Interchain/protocol packages; isolated frozen copy	node/tests-standard.jsonl
Node race detector	102 passed /102	Subset rerun of the 127, not additional unique cases	node/tests-race.jsonl
Unmodified Solidity suite	102 passed /103; 1 fixture failure	Misplaced expected revert; production guard separately confirmed	contracts/forge-run-2.log
Independent/isolation Solidity	7 passed /7	Six new tests plus one corrected existing fixture; 257 fuzz cases x 40 epochs	contracts/forge-independent-final.log
Managed-relay existing suite	92 passed /92	Includes quote/funding/finality behavior; some concurrency-labelled tests use a fake pool	sponsorship/managed-relay-tests.tap
Admin/security targeted suite	20 passed /20	Health, read-only reconciliation, role/rotation and Nginx checks	sponsorship/admin-security-tests.tap
Browser-side unit files	273 passed /280	Five stale assertions; two missing-Chromium failures; 39 files invoked separately	ui/web-tests-summary.json and per-file logs
Indexer suite	136 passed /137	One stale assertion rejecting now-intended pinned eth_call	indexer/indexer-tests.log
Native-relayer suite	14 passed /14	Offline current-source regression checks	relayer/relayer-tests.log
New sponsor fault checks	4 passed /4	Passing reproduces nonce/interruption, RPC isolation, expiry and lifecycle conditions	sponsorship/auditor-fault-tests.tap
Historical sponsor regressions	4 passed /4	Above-safe/orphan rejection and bounded exact-transfer gas estimation	sponsorship/historical-sponsor-current.tap
Historical fee backfill reproduction	1 passed /1	Passing confirms still-open L-06 rollback	sponsorship/historical-l06-current.tap
Historical indexer checks	3 passed /3	Real SQL N-11 starvation plus route/shared event-bound failures	indexer/historical-checks.tap
Actual PostgreSQL-engine scenarios	Executed with PGlite 0.5.12	Restricted-role mismatch/rollback; nonce uniqueness; N-05/N-12 candidate SQL. No multi-process stress	sponsorship/sql-permissions.log;historical-n05-n12-sql.log
Current admin and native UI checks	Two admin conditions and one UI composition reproduced	Actual functions with synthetic offline fixtures; no live deployment/claim	contracts/admin-reassessment-summary.json;deferred-native-ui-summary.json
Read-only deployed runtimes	57 /57 receipt hashes match	Fresh source bodies match outside explained immutable/metadata regions	contracts/runtime-comparison.json;live/observations.json
Read-only route configuration	393 matches /424 observations; 0 mismatches	31 descriptive values; 8 valid routes and 16 wrong-binding rejections; separate 6 set / 3 digest / 3 receipt checks	live/route-configuration.json

The source suites ran on isolated copies. Node used Go 1.23.11; JavaScript used Node 24.22.1; Solidity used solc 0.8.24 and Forge 1.5.1. The configured Prague compiler target was normalized to the latest target supported by that compiler, Cancun, while the EIP-2537-capable test runtime executed the cryptographic vectors. Exact settings and dependency fingerprints are in the evidence. PGlite 0.5.12 executes PostgreSQL SQL semantics in WASM; it does not establish production process-level lock fairness, deployment grants or concurrent failure recovery.

The race run is a rerun of 102 tests from the 127-test node suite, not 102 additional unique security cases. The seven final independent/isolation Solidity results comprise six new auditor tests and one corrected existing fixture. The 257 fuzz cases are iterations of one property, not 257 different test functions. The custom fault tests passing confirms their asserted behavior, including open failures. Initial missing-dependency, sandbox-loopback and missing-browser failures are distinguished from production faults and from completed reruns.

Work not performed

No full malicious consensus proposal, production false-RPC takeover, live reorganization, paid transfer, funded smart-wallet claim, destructive database/host crash, sustained gossip flood or complete validator rollout was performed. No formal verification of every protocol invariant, exhaustive compiler equivalence or independently attested provider topology was available. Browser smoke checks did not execute successfully because the required browser binary was absent. The report does not infer a working real-wallet matrix from unit tests.

The automated security filter stopped further exploit-oriented node work. Already completed local checks were segregated, not expanded or reattempted through another tool. The unfinished first-disagreement witness scenario is described from source only. Public evidence excludes executable reproductions and detailed unrepaired accounting outputs. These limits reduce certainty about full exploitation; they do not establish safe launch readiness.

11. Reassessment of both historical audits

11.1 Historical artifact provenance and completeness

The24 October public register identifies a29-page PDF with SHA-256 `6a1423bd937eb261adf2b0da15085f7cb09dcb8ba82d16e2ea3e48e64d8ebab4`. The recovered readable PDF copy has 252,266 bytes and SHA-256 `df4f43d0aa070b46ea1657732515f39ed3bd4c56391bfe11151ba03759a4640d`; its text is German. It was used as a readable technical source but is not claimed to be the exact committed original identity. The67-entry October24 evidence ZIP has 862,448 bytes and SHA-256 `66dbc0551b4602686903b650eeda36ab090a2eac22d29de39f8d1b0290d4ded2`, exactly matching the historical commitment. The PDF discrepancy remains unresolved and is not silently repaired by changing the old register.

The35-page October25 original PDF and137-entry confidential ZIP were not recovered from connected storage. Its public report/ledger is incomplete at finding level. The original final response dated 2026-10-25T10:42:18Z supplied the 12 new N-01 through N-12 conditions and the carried-forward inventory. This is secondary historical evidence, not authenticated original report bytes. Current code, corrections and test results were then independently examined. No missing original PoC, test output or finding line number was invented.

The26-entry v2 unresolved set consists of H-01, M-04 through M-06, L-01 through L-07, I-01 through I-03 and N-01 through N-12. The earlier M-01/M-02 were historically marked verified and M-03 fixed in code; they remain individually reassessed in the 17-entry v1 matrix. The later L-02 description concerns chain-specific gas overhead, while the earlier L-02 concerns code-bearing wallets. Both descriptions are preserved under their dates; their shared gas-estimation correction is counted once as a present technical control.

2026-10-24 - 17 preserved identities

ID	Historical severity	Current severity	Disposition	Current entry
H-01	High	Medium	OPEN	F-05
M-01	Medium	Resolved original condition	VERIFIED	Original condition closed/pending direct verification
M-02	Medium	Resolved original condition	VERIFIED	Original condition closed/pending direct verification
M-03	Medium	Resolved original condition	FIXED_IN_CODE	Original condition closed/pending direct verification
M-04	Medium	Medium	OPEN	F-29
M-05	Medium	Medium	OPEN	F-03
M-06	Medium	Resolved original condition	VERIFIED	Original condition closed/pending direct verification
L-01	Low	Low	OPEN	F-13
L-02	Low	Resolved original gas-estimation condition	VERIFIED	Original condition closed/pending direct verification
L-03	Low	Low	OPEN	F-10
L-04	Low	Low	OPEN	F-22
L-05	Low	Low	OPEN	F-23
L-06	Low	Low	OPEN	F-24
L-07	Low	Low	OPEN	F-25
I-01	Informational	Low (combined assurance drift)	OPEN	F-14
I-02	Informational	Informational	OPEN	F-27
I-03	Informational	Informational	OPEN	F-28

2026-10-25 - 26 preserved identities

ID	Historical severity	Current severity	Disposition	Current entry
H-01	High	Medium	OPEN	F-05
M-04	Medium	Medium	OPEN	F-29
M-05	Medium	Medium	OPEN	F-03
M-06	Medium	Resolved original condition	VERIFIED	Original condition closed/pending direct verification
L-01	Low	Low	OPEN	F-13
L-02	Low	Resolved original gas-estimation condition	VERIFIED	Original condition closed/pending direct verification
L-03	Low	Low	OPEN	F-10
L-04	Low	Low	OPEN	F-22
L-05	Low	Low	OPEN	F-23
L-06	Low	Low	OPEN	F-24
L-07	Low	Low	OPEN	F-25
I-01	Informational	Low (combined assurance drift)	OPEN	F-14
I-02	Informational	Informational	OPEN	F-27
I-03	Informational	Informational	OPEN	F-28
N-01	High	Medium	OPEN	F-04
N-02	High	Resolved original condition	VERIFIED	Original condition closed/pending direct verification
N-03	Medium	Medium	OPEN	F-20
N-04	Medium	Medium	OPEN	F-21
N-05	High	Resolved original circular stage dependency	VERIFIED	Original condition closed/pending direct verification
N-06	Medium	Medium	OPEN	F-17
N-07	Medium	Resolved original aggregate-accounting condition	VERIFIED	Original condition closed/pending direct verification
N-08	Medium	Resolved original premature-confirmation condition	VERIFIED	Original condition closed/pending direct verification
N-09	Medium	Medium	OPEN	F-09

ID	Historical severity	Current severity	Disposition	Current entry
N-10	Low	Resolved original condition with bounded local retention	VERIFIED	Original condition closed/pending direct verification
N-11	Medium	Medium	OPEN	F-26
N-12	Medium	Resolved original no-promise candidate poisoning condition	VERIFIED	Original condition closed/pending direct verification

11.2 Finding-by-finding evidence

The following records retain original severity separately, name the current disposition, explain the failure boundary, identify corrective merge evidence, and state the actual validation and production limit. Repeated date-qualified identities refer to the same underlying present defect unless the record states a changed historical condition.

2026-10-24 / H-01 - External RPC source evidence and correlated-provider trust

Historical: High. Current: Medium. Disposition: OPEN.

Original condition and boundary. Common external RPC sources supplied signer source evidence, including XGR. Same-provider consistency checks and failover did not independently authenticate the provider view. Control over source evidence consumed by enough otherwise honest signers; a malicious relayer alone is insufficient. Currently external evidence needs two matching operator-labelled complete witnesses, while native XGR uses locally committed state.

Current assessment. Each external witness is pinned to one endpoint for the complete receipt/route/FeeVault verification; exact block, transaction, log index, message, route and fee fields must match. One successful operator, duplicate labels or two disagreeing observations cannot reach the threshold. Any matching pair of distinct labels returns immediately. An earlier disagreement is not a global conflict veto and all configured providers need not be queried. Native XGR uses its synchronized local committed chain. L2 source evidence requires safe finality with numeric canonical hash equality and no latest fallback. Operator labels do not establish upstream independence. Two correlated matching views can affect every signer. This is not a provider-independent header/receipt inclusion proof; L2 safe is not final Ethereum settlement.

Source anchors. `interchain/config.go:47-71`; `interchain/evm/rpc_evidence_quorum.go:31-113`; `interchain/runtime/iln_direct_signing.go:27-68`; `interchain/runtime/iln_direct_signing.go:95-135`; `interchain/evm/finality.go:17-62`; `audits/H01_RPC_WITNESS_SECURITY_EVIDENCE.md`.

Correction history. xgr-node PR58, merge `b2c3bb26b9efff774e9d16a91c212d71526b59e2` (Merged mitigation is present; correlated external-source trust remains); xgr-node PR59, merge `39175b868dfd39da17be9d6a87de87273c6b85bf` (Merged mitigation is present; correlated external-source trust remains); xgr-node PR62, merge `0184eaec64a4634c5604fa734652afe13cb8feb6` (Merged mitigation is present; correlated external-source trust remains).

Independent checks. TestIndependentSourceWitnessRequiresExactBlockAndReceipt PASS (Exact witness equality.); TestTwoIndependentOperatorsWithFailover PASS (Operator threshold and failover.); TestOneOperatorAndConflictingProvidersFailClosed PASS (One surviving operator and a conflicting pair reject; not evidence of a global conflict veto.); TestSafeFinalityNoFallbackToLatest PASS (Finality policy.); TestReceiptMustMatchFinalizedCanonicalBlockHash PASS (Canonical block binding.)

Production/release limit. Published v3.3.8 download digest and embedded VCS revision match the frozen source. Actual installed validator binary hashes remain unverified. The later-added first-honest-disagreement/next-matching-pair case was not run after the automated interruption; current behavior follows static control flow. No real-provider compromise, forged live receipt or production mint was created. Current residual maps to F-05.

2026-10-24 / M-01 - Gas sponsorship accepts source confirmations below the adopted native finality boundary

Historical: Medium. Current: Resolved original condition. Disposition: VERIFIED.

Original condition and boundary. findWalletSourceTx accepted latest plus a confirmation depth without requiring the L2 safe head or matching the receipt block hash to the canonical block. checkCandidate reused that confirmed flag to authorize a company-funded gas grant. The optional sponsor is active and funded. An otherwise valid payer-bound paid source operation lies above the safe head or its receipt becomes orphaned. Route, fee, wallet and budget checks remain necessary. This concerns sponsor treasury exposure, not additional Direct-BLS mint authority.

Current assessment. The shared native-finality helper checks chain identity, requires the configured native head, pins that head by number/hash and compares the source receipt block hash. findWalletSourceTx returns a nonconfirmed state above that head, and sponsorOneCandidate refuses it before reservation or payment. The original latest=112/source=100/safe=64 condition and the orphaned receipt condition both fail closed in the actual current sponsor entrypoint.

Source anchors. `apps/web/chain-finality.js:15-50`; `apps/web/wallet-transfers.js:387-399`; `services/managed-relay/gas-sponsor.mjs:100-116`.

Correction history. xgr-interchain PR292, merge `31e5b4116ab58ccd96f78931d762219534401f9d` (Shared native-safe source and delivery verification. The source sponsorship portion closes M-01.).

Independent checks. Two targeted tests pass: the actual sponsor entrypoint rejects source block 100 above safe 64 before reservation/send, and rejects an orphaned receipt block hash before reservation/send. Synthetic RPC and sender fixtures; no live payout. 4/4 shared-finality tests pass, including unsupported safe signals, chain policy, canonical receipt comparison and pinned Mailbox-state observations. 23/23 wallet-transfer tests pass, reused from the lead auditor's run.

Production/release limit. Current source and local failure-path behavior verified. Installed sponsor version and a real paid payout at the adopted source-finality boundary remain unverified. No bypass of the original finality threshold was found through the current sponsor entrypoint. A malicious sole RPC can fabricate mutually consistent state; the code does not supply independent consensus evidence. The protocol's native safe threshold is not a claim of stronger L1 finalization.

2026-10-24 / M-02 - Provisional destination delivery becomes permanently completed indexed state

Historical: Medium. Current: Resolved original condition. Disposition: VERIFIED.

Original condition and boundary. Mailbox state was read at latest despite a finality label; an initial true survived database refresh and wallet reconciliation after a canonical negative observation. A provisional destination execution is reorganized or an RPC returns transiently inconsistent positive state; source transfer can remain valid.

Current assessment. checkedDelivery now uses native-finality-qualified, block-pinned Mailbox state. Reconciliation revisits completed rows, persists block/hash and allows canonical false to overwrite true. The wallet accepts an independently qualified reversal. Queue starvation is separate N-11, not proof the old sticky-true condition remains.

Source anchors. `services/indexer/transfer-index.mjs:63-72`; `services/indexer/transfer-index-worker.mjs:197-225`; `apps/web/verified-journey.js:94-121`; `services/indexer/sql/010_native_delivery_finality.sql`.

Correction history. xgr-interchain PR292, merge `31e5b4116ab58ccd96f78931d762219534401f9d`.

Independent checks. Executed indexer M-02 finality-qualified false regression and browser verified-journey reversal regression; both passed. No real L2 reorganization.

Production/release limit. Current source verified; backend deployment/database migration not independently attested. Live endpoint alone does not establish rollout.

2026-10-24 / M-03 - On-demand Direct-BLS signing lacked synchronization protection

Historical: Medium. Current: Resolved original condition. Disposition: FIXED_IN_CODE.

Original condition and boundary. Public/peer quorum hints could reach the common signer without the synchronization guard used by the periodic loop, allowing eligibility checks against stale local PoS state. An unsynchronized node retains a route and locally active signer and receives an otherwise valid source-operation hint. Source evidence and destination set checks still applied.

Current assessment. signDirectILNMessage checks IsSynchronized before evidence acquisition and immediately before SignByBLS. Automatic observation and public/peer hints converge on this signer; current-set and delivery checks precede signing. Existing tests cover signer activity/key binding, but no dedicated stale/lost-sync regression for all entry paths was found. Code correction is established, but targeted entry-path and lost-synchronization tests are needed for VERIFIED.

Source anchors. `interchain/runtime/iln_direct_signing.go:92-135`; `interchain/runtime/iln_quorum_request.go:195-210`; `interchain/runtime/iln_quorum_request.go:211-238`; `consensus/ibft/interchain_runtime.go:28-75`.

Correction history. xgr-node PR58, merge `b2c3bb26b9efff774e9d16a91c212d71526b59e2` (Central early and immediate pre-signing synchronization checks); xgr-node PR59, merge `39175b868dfd39da17be9d6a87de87273c6b85bf` (Central early and immediate pre-signing synchronization checks).

Independent checks. TestInterchainSignerEligibilityIsOptInActiveAndMatchingBLS PASS (Eligibility/key binding; not a direct synchronization regression.)

Production/release limit. Published v3.3.8 download digest and embedded VCS revision match the frozen source. Actual installed validator binary hashes remain unverified. No dynamic unsynchronized or mid-proof loss-of-sync reproduction in Phase B.

2026-10-24 / M-04 - Unbounded RPC can block failover and orderly worker shutdown

Historical: Medium. Current: Medium. Disposition: OPEN.

Original condition and boundary. In the original baseline, an established remote RPC call could wait indefinitely, including while a chain-selection mutex was held, preventing failover and orderly shutdown. A stalled provider or network was sufficient; no flood was required.

Current assessment. boundedILNRPC read/evidence calls use real context cancellation, twelve-second request/four-second dial timeouts and a response limit; Worker.Close cancels that shared context. SubmitMembership and SubmitILNGovernance select a verified URL, then create txrelayer.NewTxRelayer without injecting the bounded client or worker shutdown context. Both run preflight reads through relayer.Client and then SendTransaction. The node-owned txrelayer creates its own legacy jsonrpc.NewClient. The pinned ethgo HTTP transport constructs a fasthttp client without

read/write deadlines and calls Do; those defaults are unlimited. Its Close method has no cancellation effect. WithReceiptTimeout changes the sleep between receipt polls, not the timeout of GetTransactionReceipt or any other HTTP call. These are reachable worker paths: governanceExecuteLoop synchronously calls executeGovernanceJob and is part of the WaitGroup; the main loop calls tick -> trySubmissions -> trySubmit -> SubmitMembership. Worker.Close waits for them; IBFT.Close invokes it before closing the syncer. Separately, chain-selection locks still span bounded provider I/O, finality polling can continue to five minutes after cancellation, and native receipt polling has a two-minute outer deadline without the worker shutdown context. Unbounded external submission/preflight I/O can still hold a worker and orderly shutdown despite read-side cancellation. Per-call or polling-loop limits on other clients do not impose deadlines on this separate transport. No live consensus stall is asserted. Current residual prerequisites: an authorized governance execution or eligible membership preflight/submission is active against an external chain and its separate legacy transport stalls. Actual consensus halt was not demonstrated.

Source anchors. `interchain/evm/rpc_transport.go:23-125`; `interchain/evm/rpc_failover.go:231-284`; `interchain/runtime/worker.go:325-348`; `interchain/evm/finality.go:64-86`; `consensus/ibft/interchain_runtime.go:218-238`; `interchain/runtime/governance_execute.go:24-47`; `interchain/runtime/governance_execute.go:75-83`; `interchain/evm/iln_governance_submit.go:130-153`; `interchain/evm/client.go:400-448`; `txrelayer/txrelayer.go:61-80`; `txrelayer/txrelayer.go:95-135`; `txrelayer/txrelayer.go:256-275`; `interchain/runtime/worker.go:351-372`; `interchain/runtime/worker.go:446-453`; `interchain/runtime/worker.go:1070-1082`; `interchain/runtime/worker.go:1168-1183`; `consensus/ibft/ibft.go:688-700`; `go.mod:60-63`; `go.mod:240-243`.

Correction history. xgr-node PR63, merge `fd39a0fb4d20163c6a6d93cb8cf5dc25f017f188` (PR63 corrects bounded read/evidence transport; external txrelayer submission/preflight remains outside that cancellation scope.).

Independent checks. TestILNRPCRequestCancellationOnWorkerShutdown PASS (Cancels only a boundedILNRPC parent context during mock HTTP I/O. Does not exercise txrelayer, external membership/governance submission, or complete Worker.Close.); TestILNRPCRejectsOversizedResponseAndMismatchedID PASS (Transport size and response-identity checks.)

Production/release limit. Published v3.3.8 download digest and embedded VCS revision match the frozen source. Actual installed validator binary hashes remain unverified. No new tests or transactions. No deliberately hung txrelayer request or full lifecycle shutdown reproduction was run; the conclusion is current-source and pinned-dependency static analysis. Current residual maps to F-29.

2026-10-24 / M-05 - Interchain work is not completely bounded inside the validator process

Historical: Medium. Current: Medium. Disposition: OPEN.

Original condition and boundary. Per-message goroutines, expensive proof acquisition before authentication and governance proposals without total count/maximum future lifetime limits leave aggregate work and persistence unbounded. An admitted peer submits syntactically acceptable frames. Proposals must satisfy current source/set checks. Interchain shares process and host resources with the regular validator.

Current assessment. Direct checkpoint votes call full source verification before voter membership, eligibility and signature checks. Direct vote and quorum-hint work lacks comprehensive pre-I/O global/per-peer admission. Some other frame types are throttled. Gossip starts a goroutine per delivered message. Governance proposals reject expired payloads/duplicates but have no global count/disk or maximum-future-expiry bound before insertion/persistence. Response/connection/time limits and batching reduce cost without bounding total admitted work. Separation from synchronous IBFT

verification hooks does not establish CPU, memory, RPC or disk isolation. No actual IBFT halt or invalid IBFT state was demonstrated.

Source anchors. `network/gossip.go:108-122`; `interchain/runtime/worker.go:830-880`; `interchain/runtime/iln_checkpoint.go:167-201`; `interchain/runtime/iln_quorum_request.go:211-238`; `interchain/runtime/governance.go:201-240`; `interchain/runtime/iln_storage.go:123-134`; `interchain/evm/rpc_transport.go:27-58`.

Correction history. xgr-node PR63, merge `fd39a0fb4d20163c6a6d93cb8cf5dc25f017f188` (Partial transport/batching/completed-quorum improvements; no complete aggregate admission fix); xgr-node PR75, merge `9a00ff7d30c602e2eedb0b2ba3ff988c039f553c` (Partial transport/batching/completed-quorum improvements; no complete aggregate admission fix).

Independent checks. TestILNRPCRejectsOversizedResponseAndMismatchedID PASS (Per-response bound, not aggregate isolation.); TestILNCompletedQuorumVerificationRejectsForgedAndStale PASS (Proof validity, not aggregate workload.); existing_race PASS (102 existing race tests; no workload saturation or consensus-latency assertion.)

Production/release limit. Published v3.3.8 download digest and embedded VCS revision match the frozen source. Actual installed validator binary hashes remain unverified. No live P2P flood, saturation, consensus-halt test or new attack-oriented test after the interruption. Current residual maps to F-03.

2026-10-24 / M-06 - Unresolvable route hints can indefinitely crowd discovery progress

Historical: Medium. Current: Resolved original condition. Disposition: VERIFIED.

Original condition and boundary. The first eight sorted hint files were repeatedly selected; unresolved/unknown hints remained without a lease and could indefinitely starve later valid hints in the bounded admission queue. Unresolvable public hints precede legitimate later entries. No quorum is needed to create a hint; event discovery/gossip remain alternate paths.

Current assessment. Hints sort by retry mtime/name and failed attempts rotate to the back. A fixed fifteen-minute first-seen lease cannot be renewed by retry rotation; legacy lease admission is synced. Unknown chain pairs, invalid names and conclusively noncanonical routes are removed; transient failures remain retryable. Eight-per-tick work bound remains while later legitimate hints can progress. Closure is for route-hint discovery only, not the separate fixed-order observer retry queue (N-01/NODE-A-04).

Source anchors. `interchain/runtime/iln_discovery.go:161-202`; `interchain/runtime/iln_discovery.go:209-272`; `interchain/runtime/iln_discovery_test.go:287-356`.

Correction history. xgr-node PR73, merge `7b8c88a172cb2d7f14af785955f476981bcfb582` (Exact original fairness/lease correction).

Independent checks. TestILNHintQueueCannotStarveValidRouteBehindEightInvalidNames PASS (Valid later hint served despite unusable earlier hints.); TestILNHintQueueTransientRPCFailureRotatesAndPreservesOriginalLease PASS (Rotation preserves immutable lease.); TestILNHintDiscoveryRequiresCanonicalRegistryProof PASS (Hint progress does not confer authorization.)

Production/release limit. Published v3.3.8 download digest and embedded VCS revision match the frozen source. Actual installed validator binary hashes remain unverified. No live hint-queue flooding.

2026-10-24 / L-01 - Wallet recovery does not bind Process calldata to the selected message

Historical: Low. Current: Low. Disposition: OPEN.

Original condition and boundary. Returned metadata is checked but the encoded message inside process calldata is not independently decoded and hashed against wallet intent. Compromised proof response plus a different independently valid authenticated message. Contract authentication remains required.

Current assessment. The frozen browser/indexer retain metadata, destination, selector and zero-value checks but no complete calldata-to-intent binding. Honest relayer construction is strongly bound. This can waste gas or confuse progress; no principal diversion or arbitrary mint is claimed.

Source anchors. `apps/web/transfer-actions.js:614-674`; `services/indexer/transfer-recovery.mjs:65-87`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. Current transfer-actions suite passed; exact missing browser binding established by static inspection. No malicious mainnet transaction.

Production/release limit. app.js and catalog match source; exact dependent-module rollout not fully attested. Current residual maps to F-13.

2026-10-24 / L-02 - A fixed 21,000 gas limit prevents native gas grants to code-bearing wallets

Historical: Low. Current: Resolved original gas-estimation condition. Disposition: VERIFIED.

Original condition and boundary. The sponsor always broadcast a native gift with gasLimit=21000. EIP-7702 delegated accounts and receiving contracts can execute code requiring more gas. Reservation preceded the failed transaction; its one-shot journal then required manual recovery. Optional sponsorship is active and the authenticated recipient executes receiving/delegation code requiring more than 21,000 gas. The original evidence used an actual isolated Prague delegation requiring 21,005 gas. No principal or mint-authorization bypass was alleged.

Current assessment. The worker estimates the exact sender, recipient and grant value before reserving a nonce. It accepts estimates from 21,000 through 100,000 gas, adds a rounded 20 percent margin, caps the resulting gas limit at 120,000 and checks the sponsor balance including that gas. This removes the fixed-EOA-budget assumption for supported recipients.

Source anchors. `services/managed-relay/gas-sponsor.mjs:191-215`; `services/managed-relay/gas-sponsor.mjs:219-223`.

Correction history. xgr-interchain PR308, merge `4daf33ccf38e2227f9b60015ed94b2e19c9c1038` (Exact bounded native-gift gas estimation before reservation. The PR describes L2 overhead; the same change also removes the original delegated-wallet fixed-limit condition.).

Independent checks. Two targeted tests pass through the actual sponsor entrypoint: exact-gift estimate 22005 produces gasLimit 26406 and value 1300000 wei; estimate 100001 returns unsafe-gas-estimate before any reservation. The RPC estimator and sender are mocked. The repository's static regression guard confirms estimation precedes reserveGrant, both bounds exist and fixed gasLimit:21000n is absent.

Production/release limit. No new real EIP-7702 or L2 gift transaction was sent. The original local Prague result establishes the historical trigger; current estimation-path behavior is verified with controlled RPC fixtures. Receiving wallets above the configured 100,000 estimate cap intentionally remain unsupported and fail closed. Receiver behavior may change between estimate and inclusion;

failed or ambiguous sends still require journal recovery. That recovery gap is the separately discovered S-A02, not evidence the old fixed 21,000 limit remains.

2026-10-24 / L-03 - Inherited ownership transfer can collapse service-wallet and recovery-admin separation

Historical: Low. Current: Low. Disposition: OPEN.

Original condition and boundary. The role inequality is checked at initialization and service-wallet rotation, but not at both ownership transfer stages. A pending handover can also be invalidated by a later service-wallet change. Existing recovery owner intentionally or accidentally initiates the handover and the proposed owner accepts. The current service wallet or another unprivileged actor cannot force an unsolicited takeover.

Current assessment. The role inequality is checked at initialization and service-wallet rotation, but not at both ownership transfer stages. A pending handover can also be invalidated by a later service-wallet change. The online quote signer, sponsor and fee payee can also become recovery owner, eliminating independent key recovery after a later service-key compromise. No added authority to mint or unlock bridge principal.

Source anchors. `contracts/XITAExecutionGateway.sol:31,130-161`; `access/Ownable2Step.sol:35-37,52-55`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. PASS; constructor starts with distinct roles, inherited transfer and acceptance leave owner()==serviceWallet(). Local isolated contract test; no production role mutation. The untested alternate pending-owner/service-wallet ordering is a source-proven additional case, not claimed as independently executed.

Production/release limit. Different addresses do not prove independent key custody or hardware protection. Current residual maps to F-10.

2026-10-24 / L-04 - Deployment receipt promotion uses confirmation depth while claiming finality

Historical: Low. Current: Low. Disposition: OPEN.

Original condition and boundary. The verifier authenticates the current canonical receipt and runtime code but its acceptance rule only compares latest height to receipt height. Depth does not establish the chain's chosen safe/finalized boundary. A future deployment reaches the configured depth while still above the required finality boundary, is promoted, and subsequently loses canonicality in a reorganization.

Current assessment. The verifier authenticates the current canonical receipt and runtime code but its acceptance rule only compares latest height to receipt height. Depth does not establish the chain's chosen safe/finalized boundary. A prematurely published deployment catalog can bind to a creation later removed by reorganization, disrupting recovery and configured node bindings. This does not demonstrate any false current receipt.

Source anchors. `services/admin/deployment-ledger.mjs:107-167`; `config/chains/base/chain.json`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. PASS: actual verifyDeploymentReceipt accepts Base receipt block 100 at latest 112 with 13 confirmations even though fixture safe/finalized height is 64; recorded calls never query safe/finalized. Injected read-only RPC fixture, no actual reorganization or catalog publication. Independent current-chain receipt checks are separately documented by root.

Production/release limit. Current deployed code and configuration are independently checked in this audit; no future deployment, real reorganization, production journal crash or compiler equivalence is implied. Current residual maps to F-22.

2026-10-24 / L-05 - An orphaned empty lock file blocks deployment journal recovery after process death

Historical: Low. Current: Low. Disposition: OPEN.

Original condition and boundary. A persistent empty lock file is not tied to an operating-system process lock or verifiable live owner. Abrupt termination skips finally and leaves later processes unable to mutate the journal. Admin process terminates while the mutation lock is held. No external filesystem attacker is required.

Current assessment. A persistent empty lock file is not tied to an operating-system process lock or verifiable live owner. Abrupt termination skips finally and leaves later processes unable to mutate the journal. Later writes fail with EEXIST despite restart, blocking an unresolved wallet operation from normal recovery. Existing journal bytes remain; no double broadcast, principal loss or unauthorized transaction was shown.

Source anchors. `services/admin/deployment-intents.mjs:96-117`; `services/admin/deployment-intents.mjs:203-214`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. PASS: prepared intent, simulated orphaned empty lock, two fresh store objects; read still succeeds, attachHash throws EEXIST both times, journal stays byte-identical and lock survives. The exact post-crash filesystem state was constructed locally; no production process was killed, and no actual restart timing/failure distribution was measured.

Production/release limit. Current deployed code and configuration are independently checked in this audit; no future deployment, real reorganization, production journal crash or compiler equivalence is implied. Current residual maps to F-23.

2026-10-24 / L-06 - Paid-fee backfill rejects valid rows because canonical event identity fields are omitted

Historical: Low. Current: Low. Disposition: OPEN.

Original condition and boundary. storeVerifiedOperation requires event.messageId and event.txHash, but backfillPaidFeeTax constructs an event containing only block and log fields. Even a fully verified paid receipt is rejected by the shared provenance guard and counted as held. An indexed paid-adapter operation has positive interchain_fee_wei and a missing quote_nonce. Its receipt and canonical source block verify successfully. Ordinary new ingestion is a separate path and does not require this historical backfill.

Current assessment. The exact original omission remains in the frozen code. The actual current verifiedTransfer accepts the fixture and recovers quote nonce 4242, but the actual backfill returns verified=0 and held=1. The transaction executes BEGIN followed by ROLLBACK before any INSERT. This is a fee-booking/data-quality failure, not authorization of a payment or loss of bridge principal.

Source anchors. `services/indexer/transfer-index-worker.mjs:54-61`; `services/indexer/transfer-index-worker.mjs:494-524`; `services/indexer/transfer-index-worker.mjs:517-520`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. 1/1 targeted regression passes by reproducing the original defect. The matched historical evidence fixture was relocated to the isolated testbed and its safe-head response updated to

satisfy the current finality precondition. Application source was unchanged; actual receipt verification and actual backfill/store functions were used with a recording database fixture.

Production/release limit. No production backlog was inspected. The defect is deterministic for qualifying rows under the frozen source, independent of whether such rows currently exist in production. Repeated sweeps cannot repair the omitted fields. Adding row.message_id and row.source_tx_hash to this already-verified event is the narrow corrective action, followed by a regression that reaches the successful store path. A separate selection limitation involving already non-null quote_nonce is not the original L-06 identity and must not substitute for it. Current residual maps to F-24.

2026-10-24 / L-07 - Dense historical event windows can permanently halt route indexing

Historical: Low. Current: Low. Disposition: OPEN.

Original condition and boundary. A complete but oversized event response is rejected while the unchanged block window is retried without adaptive splitting. A route/source has more actual operations than the configured window event bound; legitimate volume suffices. Synthetic malformed events were used only to exercise the early size guard in the new check.

Current assessment. The route scanner retains the size cap and no adaptive splitting; the grouped scanner scales the cap by route count but retains the same failure mode. The default worker groups routes, so the current shared cap is distinct from the original single-route threshold. Manual known-transaction recovery and announcements mitigate availability impact.

Source anchors. `services/indexer/transfer-index.mjs:236-286`; `services/indexer/transfer-index.mjs:348-360`; `services/indexer/transfer-index-worker.mjs:539-589`.

Correction history. xgr-interchain PR300, merge `b35a1a3e531081512fc51296404811decad6ffe8` (Grouped observation improves efficiency; does not add adaptive dense-window progress.).

Independent checks. Two additional isolated tests passed by reproducing the non-adaptive route and shared-source bounds. Not a live high-volume transfer test.

Production/release limit. No current dense-window production stall established. Current residual maps to F-25.

2026-10-24 / I-01 - Existing negative-test and compatibility-checker defects

Historical: Informational. Current: Low (combined assurance drift). Disposition: OPEN.

Original condition and boundary. A misplaced expected-revert is consumed by a helper constructor; a legacy compatibility checker does not recognize the intended hook receipt alias and enumerates only two chains. Running the existing checks; no adversary required.

Current assessment. The Solidity fixture still fails unchanged; an isolated corrected setup confirms the actual factory guard. The old checker still has the restrictive chain regex and direct component equality. Five UI assertions and one indexer assertion additionally drift from current catalog/behavior. These are test-assurance gaps, not demonstrated factory or hook exploits.

Source anchors. `test/XITAXGRHubTopologyV315.t.sol:82-93`; `tools/assert-xita-v320-compatible-deploy.mjs:13-19,84-95`; `.github/workflows/validate.yml`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. 103 Solidity tests:102 pass/1 fixture fail; isolated fixture validation passes. Full UI280:273 pass/5 stale assertions/2 missing-browser failures; indexer137:136 pass/1 stale assertion. Legacy checker condition statically inspected, not newly rerun.

Production/release limit. Testing quality and coverage do not attest deployed behavior. Current residual maps to F-14.

2026-10-24 / I-02 - Release workflow targets an obsolete versioning package path

Historical: Informational. Current: Informational. Disposition: OPEN.

Original condition and boundary. Linker -X flags target a package inconsistent with the module's imported versioning package; application version fields have empty defaults. A build uses the affected workflow. Go's independent VCS metadata is not controlled by these version strings.

Current assessment. The v3.3.8 release workflow still uses an incorrect linker package target. The downloaded published binary's version subcommand exited 0 and returned <none> for Release version, Git branch, Commit hash and Build time. Independent Go VCS metadata and downloaded digest match the frozen source; this is separate evidence from the broken application fields. Application self-report cannot establish provenance; correct published binary build info is not proof of per-validator installation.

Source anchors. `.github/workflows/release-light-v338.yml:124-134`; `versioning/versioning.go:9-15`; `command/version/version.go:1-30`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. Read-only published executable version subcommand Four application version fields <none>, exit 0; Go build metadata and checksum Frozen source SHA and vcs.modified=false

Production/release limit. Published v3.3.8 download digest and embedded VCS revision match the frozen source. Actual installed validator binary hashes remain unverified. No daemon start or installed host inspection. Current residual maps to F-27.

2026-10-24 / I-03 - Known compiler exposure SOL-2026-7 remains unexcluded for deployed artifacts

Historical: Informational. Current: Informational. Disposition: OPEN.

Original condition and boundary. The observed compiler version and enabled Yul optimizer fall within the advisory range. Actual miscompilation additionally requires specific intermediate-code address derivation/reassignment and runtime aliasing. Those conditions are not established for XITA; upstream Low is not a discovered Low-severity bridge vulnerability. Affected compiler/configuration and project-specific intermediate-code trigger conditions; applicability remains unproven.

Current assessment. The observed compiler version and enabled Yul optimizer fall within the advisory range. Actual miscompilation additionally requires specific intermediate-code address derivation/reassignment and runtime aliasing. Those conditions are not established for XITA; upstream Low is not a discovered Low-severity bridge vulnerability. An unresolved source-to-executable assurance boundary. Runtime correspondence and passing tests cannot exclude a compiler defect common to the source build and deployed bytecode. No confirmed miscompile or mint/unlock exploit.

Source anchors. `foundry.toml:11-16`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. No same-release compiler with the targeted fix, no L/E-disabled behavioral comparison, and no exhaustive equivalence analysis. Ordinary test coverage and general recompilation with a later version would not be definitive exclusion. 57 runtimes have no unexplained instruction differences after compiler-declared immutables and exact IPFS digest positions are separated. Metadata is not exactly reproduced. Exposed immutable bindings are checked in evidence/live/route-configuration.json.

Production/release limit. Current deployed code and configuration are independently checked in this audit; no future deployment, real reorganization, production journal crash or compiler equivalence is implied. Current residual maps to F-28.

2026-10-25 / H-01 - External RPC source evidence and correlated-provider trust

Historical: High. Current: Medium. Disposition: OPEN. Duplicate mapping: 2026-10-24/H-01.

Original condition and boundary. The original 24 October H-01 condition included common external RPC evidence for XGR. By the 25 October baseline, native XGR verification had moved to locally committed state and external-source verification used matching operator-labelled witnesses. H-01 remained High in that reassessment because correlated external witnesses still constituted a shared trust dependency. Its historical severity is preserved; the current residual assessment is Medium with the stated operational conditions. Control over source evidence consumed by enough otherwise honest signers; a malicious relayer alone is insufficient. Currently external evidence needs two matching operator-labelled complete witnesses, while native XGR uses locally committed state.

Current assessment. Each external witness is pinned to one endpoint for the complete receipt/route/FeeVault verification; exact block, transaction, log index, message, route and fee fields must match. One successful operator, duplicate labels or two disagreeing observations cannot reach the threshold. Any matching pair of distinct labels returns immediately. An earlier disagreement is not a global conflict veto and all configured providers need not be queried. Native XGR uses its synchronized local committed chain. L2 source evidence requires safe finality with numeric canonical hash equality and no latest fallback. Operator labels do not establish upstream independence. Two correlated matching views can affect every signer. This is not a provider-independent header/receipt inclusion proof; L2 safe is not final Ethereum settlement.

Source anchors. `interchain/config.go:47-71`; `interchain/evm/rpc_evidence_quorum.go:31-113`; `interchain/runtime/iln_direct_signing.go:27-68`; `interchain/runtime/iln_direct_signing.go:95-135`; `interchain/evm/finality.go:17-62`; `audits/H01_RPC_WITNESS_SECURITY_EVIDENCE.md`.

Correction history. xgr-node PR58, merge `b2c3bb26b9efff774e9d16a91c212d71526b59e2` (Merged mitigation is present; correlated external-source trust remains); xgr-node PR59, merge `39175b868dfd39da17be9d6a87de87273c6b85bf` (Merged mitigation is present; correlated external-source trust remains); xgr-node PR62, merge `0184eaec64a4634c5604fa734652afe13cb8feb6` (Merged mitigation is present; correlated external-source trust remains).

Independent checks. TestIndependentSourceWitnessRequiresExactBlockAndReceipt PASS (Exact witness equality.); TestTwoIndependentOperatorsWithFailover PASS (Operator threshold and failover.); TestOneOperatorAndConflictingProvidersFailClosed PASS (One surviving operator and a conflicting pair reject; not evidence of a global conflict veto.); TestSafeFinalityNoFallbackToLatest PASS (Finality policy.); TestReceiptMustMatchFinalizedCanonicalBlockHash PASS (Canonical block binding.)

Production/release limit. Published v3.3.8 download digest and embedded VCS revision match the frozen source. Actual installed validator binary hashes remain unverified. The later-added first-honest-disagreement/next-matching-pair case was not run after the automated interruption; current behavior follows static control flow. No real-provider compromise, forged live receipt or production mint was created. Current residual maps to F-05.

2026-10-25 / M-04 - Unbounded RPC can block failover and orderly worker shutdown

Historical: Medium. Current: Medium. Disposition: OPEN. Duplicate mapping: 2026-10-24/M-04.

Original condition and boundary. In the original baseline, an established remote RPC call could wait indefinitely, including while a chain-selection mutex was held, preventing failover and orderly shutdown. A stalled provider or network was sufficient; no flood was required.

Current assessment. boundedILNRPC read/evidence calls use real context cancellation, twelve-second request/four-second dial timeouts and a response limit; Worker.Close cancels that shared context. SubmitMembership and SubmitILNGovernance select a verified URL, then create txrelayer.NewTxRelayer without injecting the bounded client or worker shutdown context. Both run preflight reads through relayer.Client and then SendTransaction. The node-owned txrelayer creates its own legacy jsonrpc.NewClient. The pinned ethgo HTTP transport constructs a fasthttp client without read/write deadlines and calls Do; those defaults are unlimited. Its Close method has no cancellation effect. WithReceiptTimeout changes the sleep between receipt polls, not the timeout of GetTransactionReceipt or any other HTTP call. These are reachable worker paths: governanceExecuteLoop synchronously calls executeGovernanceJob and is part of the WaitGroup; the main loop calls tick -> trySubmissions -> trySubmit -> SubmitMembership. Worker.Close waits for them; IBFT.Close invokes it before closing the syncer. Separately, chain-selection locks still span bounded provider I/O, finality polling can continue to five minutes after cancellation, and native receipt polling has a two-minute outer deadline without the worker shutdown context. Unbounded external submission/preflight I/O can still hold a worker and orderly shutdown despite read-side cancellation. Per-call or polling-loop limits on other clients do not impose deadlines on this separate transport. No live consensus stall is asserted. Current residual prerequisites: an authorized governance execution or eligible membership preflight/submission is active against an external chain and its separate legacy transport stalls. Actual consensus halt was not demonstrated.

Source anchors. `interchain/evm/rpc_transport.go:23-125`; `interchain/evm/rpc_failover.go:231-284`; `interchain/runtime/worker.go:325-348`; `interchain/evm/finality.go:64-86`; `consensus/ibft/interchain_runtime.go:218-238`; `interchain/runtime/governance_execute.go:24-47`; `interchain/runtime/governance_execute.go:75-83`; `interchain/evm/iln_governance_submit.go:130-153`; `interchain/evm/client.go:400-448`; `txrelayer/txrelayer.go:61-80`; `txrelayer/txrelayer.go:95-135`; `txrelayer/txrelayer.go:256-275`; `interchain/runtime/worker.go:351-372`; `interchain/runtime/worker.go:446-453`; `interchain/runtime/worker.go:1070-1082`; `interchain/runtime/worker.go:1168-1183`; `consensus/ibft/ibft.go:688-700`; `go.mod:60-63`; `go.mod:240-243`.

Correction history. xgr-node PR63, merge `fd39a0fb4d20163c6a6d93cb8cf5dc25f017f188` (PR63 corrects bounded read/evidence transport; external txrelayer submission/preflight remains outside that cancellation scope.).

Independent checks. TestILNRPCRequestCancellationOnWorkerShutdown PASS (Cancels only a boundedILNRPC parent context during mock HTTP I/O. Does not exercise txrelayer, external membership/governance submission, or complete Worker.Close.); TestILNRPCRejectsOversizedResponseAndMismatchedID PASS (Transport size and response-identity checks.)

Production/release limit. Published v3.3.8 download digest and embedded VCS revision match the frozen source. Actual installed validator binary hashes remain unverified. No new tests or transactions. No deliberately hung txrelayer request or full lifecycle shutdown reproduction was run; the conclusion is current-source and pinned-dependency static analysis. Current residual maps to F-29.

2026-10-25 / M-05 - Interchain work is not completely bounded inside the validator process

Historical: Medium. Current: Medium. Disposition: OPEN. Duplicate mapping: 2026-10-24/M-05.

Original condition and boundary. Per-message goroutines, expensive proof acquisition before authentication and governance proposals without total count/maximum future lifetime limits leave aggregate work and persistence unbounded. An admitted peer submits syntactically acceptable frames. Proposals must satisfy current source/set checks. Interchain shares process and host resources with the regular validator.

Current assessment. Direct checkpoint votes call full source verification before voter membership, eligibility and signature checks. Direct vote and quorum-hint work lacks comprehensive pre-I/O global/per-peer admission. Some other frame types are throttled. Gossip starts a goroutine per delivered message. Governance proposals reject expired payloads/duplicates but have no global count/disk or maximum-future-expiry bound before insertion/persistence. Response/connection/time limits and batching reduce cost without bounding total admitted work. Separation from synchronous IBFT verification hooks does not establish CPU, memory, RPC or disk isolation. No actual IBFT halt or invalid IBFT state was demonstrated.

Source anchors. `network/gossip.go:108-122`; `interchain/runtime/worker.go:830-880`; `interchain/runtime/iln_checkpoint.go:167-201`; `interchain/runtime/iln_quorum_request.go:211-238`; `interchain/runtime/governance.go:201-240`; `interchain/runtime/iln_storage.go:123-134`; `interchain/evm/rpc_transport.go:27-58`.

Correction history. xgr-node PR63, merge `fd39a0fb4d20163c6a6d93cb8cf5dc25f017f188` (Partial transport/batching/completed-quorum improvements; no complete aggregate admission fix); xgr-node PR75, merge `9a00ff7d30c602e2eedb0b2ba3ff988c039f553c` (Partial transport/batching/completed-quorum improvements; no complete aggregate admission fix).

Independent checks. TestILNRPCRejectsOversizedResponseAndMismatchedID PASS (Per-response bound, not aggregate isolation.); TestILNCompletedQuorumVerificationRejectsForgedAndStale PASS (Proof validity, not aggregate workload.); existing_race PASS (102 existing race tests; no workload saturation or consensus-latency assertion.)

Production/release limit. Published v3.3.8 download digest and embedded VCS revision match the frozen source. Actual installed validator binary hashes remain unverified. No live P2P flood, saturation, consensus-halt test or new attack-oriented test after the interruption. Current residual maps to F-03.

2026-10-25 / M-06 - Unresolvable route hints can indefinitely crowd discovery progress

Historical: Medium. Current: Resolved original condition. Disposition: VERIFIED. Duplicate mapping: 2026-10-24/M-06.

Original condition and boundary. The first eight sorted hint files were repeatedly selected; unresolved/unknown hints remained without a lease and could indefinitely starve later valid hints in the bounded admission queue. Unresolvable public hints precede legitimate later entries. No quorum is needed to create a hint; event discovery/gossip remain alternate paths.

Current assessment. Hints sort by retry mtime/name and failed attempts rotate to the back. A fixed fifteen-minute first-seen lease cannot be renewed by retry rotation; legacy lease admission is synced. Unknown chain pairs, invalid names and conclusively noncanonical routes are removed; transient failures remain retryable. Eight-per-tick work bound remains while later legitimate hints can progress. Closure is for route-hint discovery only, not the separate fixed-order observer retry queue (N-01/NODE-A-04).

Source anchors. `interchain/runtime/iln_discovery.go:161-202`; `interchain/runtime/iln_discovery.go:209-272`; `interchain/runtime/iln_discovery_test.go:287-356`.

Correction history. xgr-node PR73, merge `7b8c88a172cb2d7f14af785955f476981bcfb582` (Exact original fairness/lease correction).

Independent checks. TestILNHintQueueCannotStarveValidRouteBehindEightInvalidNames PASS (Valid later hint served despite unusable earlier hints.); TestILNHintQueueTransientRPCFailureRotatesAndPreservesOriginalLease PASS (Rotation preserves immutable lease.); TestILNHintDiscoveryRequiresCanonicalRegistryProof PASS (Hint progress does not confer authorization.)

Production/release limit. Published v3.3.8 download digest and embedded VCS revision match the frozen source. Actual installed validator binary hashes remain unverified. No live hint-queue flooding.

2026-10-25 / L-01 - Wallet recovery does not bind Process calldata to the selected message

Historical: Low. Current: Low. Disposition: OPEN. Duplicate mapping: 2026-10-24/L-01.

Original condition and boundary. Returned metadata is checked but the encoded message inside process calldata is not independently decoded and hashed against wallet intent. Compromised proof response plus a different independently valid authenticated message. Contract authentication remains required.

Current assessment. The frozen browser/indexer retain metadata, destination, selector and zero-value checks but no complete calldata-to-intent binding. Honest relayer construction is strongly bound. This can waste gas or confuse progress; no principal diversion or arbitrary mint is claimed.

Source anchors. `apps/web/transfer-actions.js:614-674`; `services/indexer/transfer-recovery.mjs:65-87`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. Current transfer-actions suite passed; exact missing browser binding established by static inspection. No malicious mainnet transaction.

Production/release limit. app.js and catalog match source; exact dependent-module rollout not fully attested. Current residual maps to F-13.

2026-10-25 / L-02 - A fixed 21,000 gas limit can fail native gifts on chains with extra execution overhead

Historical: Low. Current: Resolved original gas-estimation condition. Disposition: VERIFIED. Duplicate mapping: 2026-10-24/L-02. The v2 public register describes a later chain-specific native-gas failure under the same label; preserve both descriptions. PR308 addresses both estimation boundaries.

Original condition and boundary. The old native-gift transaction supplied a fixed 21,000 gas limit even when the destination-chain estimate for the exact transfer was higher. Optional sponsorship is active, a paid immutable grant is due, and the destination requires more than 21,000 gas for the exact native gift.

Current assessment. The exact transfer is estimated before nonce reservation and sent with a bounded 20 percent margin. Current entrypoint tests demonstrate the transaction can carry more than 21,000 gas and rejects abnormal estimates before reserving funds.

Source anchors. `services/managed-relay/gas-sponsor.mjs:191-223`.

Correction history. xgr-interchain PR308, merge `4daf33ccf38e2227f9b60015ed94b2e19c9c1038`.

Independent checks. The same two gas-estimation tests cited for 24-Oct L-02 apply. They are reused evidence, not two additional executed tests.

Production/release limit. Destination-specific live gift acceptance was not performed; sponsor readiness was false in the read-only live observation. Estimate-to-inclusion changes and definitively failed or ambiguous transaction recovery remain operational concerns; no claim is made that every possible recipient fits the explicit gas policy.

2026-10-25 / L-03 - Inherited ownership transfer can collapse service-wallet and recovery-admin separation

Historical: Low. Current: Low. Disposition: OPEN. Duplicate mapping: 2026-10-24/L-03.

Original condition and boundary. The role inequality is checked at initialization and service-wallet rotation, but not at both ownership transfer stages. A pending handover can also be invalidated by a later service-wallet change. Existing recovery owner intentionally or accidentally initiates the handover and the proposed owner accepts. The current service wallet or another unprivileged actor cannot force an unsolicited takeover.

Current assessment. The role inequality is checked at initialization and service-wallet rotation, but not at both ownership transfer stages. A pending handover can also be invalidated by a later service-wallet change. The online quote signer, sponsor and fee payee can also become recovery owner, eliminating independent key recovery after a later service-key compromise. No added authority to mint or unlock bridge principal.

Source anchors. `contracts/XITAExecutionGateway.sol:31,130-161`; `access/Ownable2Step.sol:35-37,52-55`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. PASS; constructor starts with distinct roles, inherited transfer and acceptance leave owner()==serviceWallet(). Local isolated contract test; no production role mutation. The untested alternate pending-owner/service-wallet ordering is a source-proven additional case, not claimed as independently executed.

Production/release limit. Different addresses do not prove independent key custody or hardware protection. Current residual maps to F-10.

2026-10-25 / L-04 - Deployment receipt promotion uses confirmation depth while claiming finality

Historical: Low. Current: Low. Disposition: OPEN. Duplicate mapping: 2026-10-24/L-04.

Original condition and boundary. The verifier authenticates the current canonical receipt and runtime code but its acceptance rule only compares latest height to receipt height. Depth does not establish the chain's chosen safe/finalized boundary. A future deployment reaches the configured depth while still above the required finality boundary, is promoted, and subsequently loses canonicality in a reorganization.

Current assessment. The verifier authenticates the current canonical receipt and runtime code but its acceptance rule only compares latest height to receipt height. Depth does not establish the chain's chosen safe/finalized boundary. A prematurely published deployment catalog can bind to a creation later removed by reorganization, disrupting recovery and configured node bindings. This does not demonstrate any false current receipt.

Source anchors. `services/admin/deployment-ledger.mjs:107-167`; `config/chains/base/chain.json`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. PASS: actual verifyDeploymentReceipt accepts Base receipt block 100 at latest 112 with 13 confirmations even though fixture safe/finalized height is 64; recorded calls never query safe/finalized. Injected read-only RPC fixture, no actual reorganization or catalog publication. Independent current-chain receipt checks are separately documented by root.

Production/release limit. Current deployed code and configuration are independently checked in this audit; no future deployment, real reorganization, production journal crash or compiler equivalence is implied. Current residual maps to F-22.

2026-10-25 / L-05 - An orphaned empty lock file blocks deployment journal recovery after process death

Historical: Low. Current: Low. Disposition: OPEN. Duplicate mapping: 2026-10-24/L-05.

Original condition and boundary. A persistent empty lock file is not tied to an operating-system process lock or verifiable live owner. Abrupt termination skips finally and leaves later processes unable to mutate the journal. Admin process terminates while the mutation lock is held. No external filesystem attacker is required.

Current assessment. A persistent empty lock file is not tied to an operating-system process lock or verifiable live owner. Abrupt termination skips finally and leaves later processes unable to mutate the journal. Later writes fail with EEXIST despite restart, blocking an unresolved wallet operation from normal recovery. Existing journal bytes remain; no double broadcast, principal loss or unauthorized transaction was shown.

Source anchors. `services/admin/deployment-intents.mjs:96-117`; `services/admin/deployment-intents.mjs:203-214`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. PASS: prepared intent, simulated orphaned empty lock, two fresh store objects; read still succeeds, attachHash throws EEXIST both times, journal stays byte-identical and lock survives. The exact post-crash filesystem state was constructed locally; no production process was killed, and no actual restart timing/failure distribution was measured.

Production/release limit. Current deployed code and configuration are independently checked in this audit; no future deployment, real reorganization, production journal crash or compiler equivalence is implied. Current residual maps to F-23.

2026-10-25 / L-06 - Paid-fee backfill rejects valid rows because canonical event identity fields are omitted

Historical: Low. Current: Low. Disposition: OPEN. Duplicate mapping: 2026-10-24/L-06.

Original condition and boundary. storeVerifiedOperation requires event.messageId and event.txHash, but backfillPaidFeeTax constructs an event containing only block and log fields. Even a fully verified paid receipt is rejected by the shared provenance guard and counted as held. An indexed paid-adapter operation has positive interchain_fee_wei and a missing quote_nonce. Its receipt and canonical source block verify successfully. Ordinary new ingestion is a separate path and does not require this historical backfill.

Current assessment. The exact original omission remains in the frozen code. The actual current verifiedTransfer accepts the fixture and recovers quote nonce 4242, but the actual backfill returns verified=0 and held=1. The transaction executes BEGIN followed by ROLLBACK before any INSERT. This is a fee-booking/data-quality failure, not authorization of a payment or loss of bridge principal.

Source anchors. `services/indexer/transfer-index-worker.mjs:54-61`; `services/indexer/transfer-index-worker.mjs:494-524`; `services/indexer/transfer-index-worker.mjs:517-520`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. 1/1 targeted regression passes by reproducing the original defect. The matched historical evidence fixture was relocated to the isolated testbed and its safe-head response updated to satisfy the current finality precondition. Application source was unchanged; actual receipt verification and actual backfill/store functions were used with a recording database fixture.

Production/release limit. No production backlog was inspected. The defect is deterministic for qualifying rows under the frozen source, independent of whether such rows currently exist in production. Repeated sweeps cannot repair the omitted fields. Adding row.message_id and row.source_tx_hash to this already-verified event is the narrow corrective action, followed by a regression that reaches the successful store path. A separate selection limitation involving already non-null quote_nonce is not the original L-06 identity and must not substitute for it. Current residual maps to F-24.

2026-10-25 / L-07 - Dense historical event windows can permanently halt route indexing

Historical: Low. Current: Low. Disposition: OPEN. Duplicate mapping: 2026-10-24/L-07.

Original condition and boundary. A complete but oversized event response is rejected while the unchanged block window is retried without adaptive splitting. A route/source has more actual operations than the configured window event bound; legitimate volume suffices. Synthetic malformed events were used only to exercise the early size guard in the new check.

Current assessment. The route scanner retains the size cap and no adaptive splitting; the grouped scanner scales the cap by route count but retains the same failure mode. The default worker groups routes, so the current shared cap is distinct from the original single-route threshold. Manual known-transaction recovery and announcements mitigate availability impact.

Source anchors. `services/indexer/transfer-index.mjs:236-286`; `services/indexer/transfer-index.mjs:348-360`; `services/indexer/transfer-index-worker.mjs:539-589`.

Correction history. xgr-interchain PR300, merge `b35a1a3e531081512fc51296404811decad6ffe8` (Grouped observation improves efficiency; does not add adaptive dense-window progress.).

Independent checks. Two additional isolated tests passed by reproducing the non-adaptive route and shared-source bounds. Not a live high-volume transfer test.

Production/release limit. No current dense-window production stall established. Current residual maps to F-25.

2026-10-25 / I-01 - Existing negative-test and compatibility-checker defects

Historical: Informational. Current: Low (combined assurance drift). Disposition: OPEN. Duplicate mapping: 2026-10-24/I-01.

Original condition and boundary. A misplaced expected-revert is consumed by a helper constructor; a legacy compatibility checker does not recognize the intended hook receipt alias and enumerates only two chains. Running the existing checks; no adversary required.

Current assessment. The Solidity fixture still fails unchanged; an isolated corrected setup confirms the actual factory guard. The old checker still has the restrictive chain regex and direct component equality. Five UI assertions and one indexer assertion additionally drift from current catalog/behavior. These are test-assurance gaps, not demonstrated factory or hook exploits.

Source anchors. `test/XITAXGRHubTopologyV315.t.sol:82-93`; `tools/assert-xita-v320-compatible-deploy.mjs:13-19,84-95`; `.github/workflows/validate.yml`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. 103 Solidity tests:102 pass/1 fixture fail; isolated fixture validation passes. Full UI280:273 pass/5 stale assertions/2 missing-browser failures; indexer137:136 pass/1 stale assertion. Legacy checker condition statically inspected, not newly rerun.

Production/release limit. Testing quality and coverage do not attest deployed behavior. Current residual maps to F-14.

2026-10-25 / I-02 - Release workflow targets an obsolete versioning package path

Historical: Informational. Current: Informational. Disposition: OPEN. Duplicate mapping: 2026-10-24/I-02.

Original condition and boundary. Linker -X flags target a package inconsistent with the module's imported versioning package; application version fields have empty defaults. A build uses the affected workflow. Go's independent VCS metadata is not controlled by these version strings.

Current assessment. The v3.3.8 release workflow still uses an incorrect linker package target. The downloaded published binary's version subcommand exited 0 and returned <none> for Release version, Git branch, Commit hash and Build time. Independent Go VCS metadata and downloaded digest match the frozen source; this is separate evidence from the broken application fields. Application self-report cannot establish provenance; correct published binary build info is not proof of per-validator installation.

Source anchors. `.github/workflows/release-light-v338.yml:124-134`; `versioning/versioning.go:9-15`; `command/version/version.go:1-30`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. Read-only published executable version subcommand Four application version fields <none>, exit 0; Go build metadata and checksum Frozen source SHA and vcs.modified=false

Production/release limit. Published v3.3.8 download digest and embedded VCS revision match the frozen source. Actual installed validator binary hashes remain unverified. No daemon start or installed host inspection. Current residual maps to F-27.

2026-10-25 / I-03 - Known compiler exposure SOL-2026-7 remains unexcluded for deployed artifacts

Historical: Informational. Current: Informational. Disposition: OPEN. Duplicate mapping: 2026-10-24/I-03.

Original condition and boundary. The observed compiler version and enabled Yul optimizer fall within the advisory range. Actual miscompilation additionally requires specific intermediate-code address derivation/reassignment and runtime aliasing. Those conditions are not established for XITA; upstream Low is not a discovered Low-severity bridge vulnerability. Affected compiler/configuration and project-specific intermediate-code trigger conditions; applicability remains unproven.

Current assessment. The observed compiler version and enabled Yul optimizer fall within the advisory range. Actual miscompilation additionally requires specific intermediate-code address derivation/reassignment and runtime aliasing. Those conditions are not established for XITA; upstream Low is not a discovered Low-severity bridge vulnerability. An unresolved source-to-executable assurance boundary. Runtime correspondence and passing tests cannot exclude a compiler defect common to the source build and deployed bytecode. No confirmed miscompile or mint/unlock exploit.

Source anchors. `foundry.toml:11-16`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. No same-release compiler with the targeted fix, no L/E-disabled behavioral comparison, and no exhaustive equivalence analysis. Ordinary test coverage and general recompilation with a later version would not be definitive exclusion. 57 runtimes have no unexplained instruction differences after compiler-declared immutables and exact IPFS digest positions are separated. Metadata is not exactly reproduced. Exposed immutable bindings are checked in evidence/live/route-configuration.json.

Production/release limit. Current deployed code and configuration are independently checked in this audit; no future deployment, real reorganization, production journal crash or compiler equivalence is implied. Current residual maps to F-28.

2026-10-25 / N-01 - One failed operation can stall the shared source-observer cursor

Historical: High. Current: Medium. Disposition: OPEN.

Original condition and boundary. One failed source operation in a shared scan window prevented progress of route cursors and could hold healthy transfers behind the same repeated work. A malformed or temporarily unverifiable operation is observed in a shared source scan. Impact is recovery/liveness, not authority to sign false source evidence.

Current assessment. Healthy siblings are processed in the same window. Failed observations enter an immutable file- and directory-synced retry journal before the cursor can pass them. Every retry invokes full current proof/signing checks. Journal content is a hint, not authorization. Journal limits are 4096 records per route, twenty-four retries per source poll and two per route, with thirty-second minimum retry interval. Routes are visited in fixed sorted order; at least twelve earlier routes with two continuously eligible records each can consume the budget before a late route is attempted. Corruption/capacity failures propagate at source-group scope; failed work is retained rather than discarded. The original blocker is materially mitigated; autonomous fairness and journal-failure isolation remain incomplete. The demonstrated scheduler boundary requires a later route behind at least twelve earlier routes with two continuously eligible records each; it is not an observed stall in the current smaller route set.

Source anchors. `interchain/runtime/iln_observer_worker.go:128-161`; `interchain/runtime/iln_observer_worker.go:180-210`; `interchain/runtime/iln_observer_retry.go:17-25`; `interchain/runtime/iln_observer_retry.go:71-105`; `interchain/runtime/iln_observer_retry.go:141-199`.

Correction history. xgr-node PR72, merge `ecb2841ed622b75a3c4d96cabacc7a3adb3de3e5` (Substantial shared-window and durable admission improvement; not full fair recovery/capacity isolation).

Independent checks.
TestSharedObserverContinuesSigningHealthySiblingButNeverAdvancesFailedWindow PASS (Current assertions actually require cursor advancement after durable retry admission and a retained failed-message record. The old name is not interpreted literally.); TestObserverRetryDurableDedupConflictAndReverification PASS (Immutable deduplication, conflict rejection and proof re-verification.); TestObserverRetryRejectsCorruptJournalWithoutSigning PASS (Corruption cannot authorize a signature.)

Production/release limit. Published v3.3.8 download digest and embedded VCS revision match the frozen source. Actual installed validator binary hashes remain unverified. No disk power-loss or production large-route recovery test. No Phase B adversarial reproduction; safe Phase A scheduler findings are already in the frozen report. Current residual maps to F-04.

2026-10-25 / N-02 - Valid multi-Dispatch receipts can be rejected

Historical: High. Current: Resolved original condition. Disposition: VERIFIED.

Original condition and boundary. Unrelated valid canonical Mailbox dispatches in the same successful source transaction could cause rejection of the selected fee-qualified operation. One successful source transaction dispatches multiple legitimate messages. The issue blocks liveness; it does not demonstrate signature bypass.

Current assessment. Dispatch bytes are decoded and hashed; unrelated messages are ignored before selected-message route-topic checks. Exactly one matching Gateway operation and bound canonical Dispatch remain required. Same-message topic conflicts and duplicated matching Gateway/Dispatch events reject. Current verifier behavior verified locally; no production installation claim. Malformed canonical logs may remain fail-closed under the verifier's policy.

Source anchors. `interchain/evm/iln_direct_operation.go:27-85`.

Correction history. xgr-node PR71, merge `2a001b61b710f2a058eda7e66404b58b9a6b2ac5` (Matching-message dispatch selection and duplicate/topic-conflict regressions).

Independent checks. TestDirectReceiptAcceptsUnrelatedCanonicalDispatches PASS (Positive multi-dispatch receipt.); TestDirectReceiptRejectsSameMessageWithConflictingDispatchTopics PASS (Same-message router/destination conflict.); TestDirectReceiptRejectsDuplicatedGatewayOrMailboxEvents PASS (Selected operation/dispatch uniqueness.); TestDirectReceiptFailsOnMissingOrDuplicateGatewayOperation PASS (Missing or duplicate matching Gateway operation.)

Production/release limit. Published v3.3.8 download digest and embedded VCS revision match the frozen source. Actual installed validator binary hashes remain unverified. No live-chain batched transfer submitted.

2026-10-25 / N-03 - Pending recovery work can be deleted before durable replacement

Historical: Medium. Current: Medium. Disposition: OPEN.

Original condition and boundary. Pending recovery work may be deleted before durable replacement for the current set exists. Already-advanced source cursors can leave it without automatic rediscovery. An undelivered persisted vote sees an absent route after restart or a destination-set rotation; replacement signing then fails/is interrupted. Temporary source/destination unavailability or lost synchronization suffices.

Current assessment. rebroadcastILNCheckpointVotes deletes a persisted vote immediately when its route is absent. On set rotation, it deletes the old vote before calling signDirectILNMessage; an error only logs waiting and creates no replacement recovery record in this branch. After thirty days, undelivered quorum archives may be pruned when fresh source verification suggests regeneration is possible; canRegenerateILNQuorum does not persist a replacement or recovery job. The failed-observation journal added for N-01 is not invoked by these rotation/pruning paths. Recovery can depend on another node's retained archive or another operator/user hint despite already-paid source work. No principal loss or false BLS authorization demonstrated.

Source anchors. `interchain/runtime/iln_checkpoint.go:131-164`; `interchain/runtime/iln_checkpoint.go:362-407`; `interchain/runtime/iln_storage.go:78-120`; `interchain/runtime/iln_direct_signing.go:95-135`; `interchain/runtime/iln_observer_worker.go:137-149`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. TestILNStoragePrunesOnlyProvenDeliveredQuorums PASS (Young pending/unverifiable old pending data retained; proven delivered removed. Does not cover re-verifiable

old pending archive deletion without a replacement.); TestILNDiscoveryRestoresRouteAfterWorkerRestart PASS (Clean catalog restart recovery, not lost vote handoff.); TestILNCompletedQuorumVerificationRejectsForgedAndStale PASS (Aggregate integrity/current set, not durable pending handoff.)

Production/release limit. Published v3.3.8 download digest and embedded VCS revision match the frozen source. Actual installed validator binary hashes remain unverified. No destructive restart, rotation, interrupted handoff or power-loss reproduction. Original detailed reproduction is unavailable; current conclusion is static order/deletion analysis. Current residual maps to F-20.

2026-10-25 / N-04 - Incomplete successful discovery responses can advance durable cursors

Historical: Medium. Current: Medium. Disposition: OPEN.

Original condition and boundary. Returned events are checked, but a successful incomplete/empty single-provider log list is accepted as a completed range. Cursors advance past omitted events. One external source discovery provider returns a successful partial/empty log list for a window containing relevant events. Signing actually found messages still requires independent full source witnesses.

Current assessment. ScanILNMultiGatewayWindow retries recognized provider errors, but returns immediately on the first successful log response. scanSharedILNSource advances all relevant route cursors after handling returned events only; missing events create no retry records. RouteAdded discovery has the same single-provider completeness dependency before durable cursor progress. Native XGR scans locally committed blocks/receipts and does not use external discovery for this source. Independent witness checking protects authenticity of found messages, not completeness of discovery. Other nodes, peer hints and explicit public recovery mitigate liveness but do not prove autonomous reconciliation.

Source anchors. `interchain/evm/iln_multi_gateway_scan.go:42-100`; `interchain/evm/iln_multi_gateway_scan.go:103-138`; `interchain/runtime/iln_observer_worker.go:110-155`; `interchain/evm/iln_discovery.go:39-63`; `interchain/runtime/iln_discovery.go:285-321`.

Correction history. No corrective merge closing the condition was identified in the inspected history.

Independent checks. TestSharedILNObserverReducesExternalRequestsAndPreservesDurableCursors PASS (Normal batching/cursor behavior; not successful omitted-log completeness.); TestSharedILNObserverLateRouteBackfillsWithoutRepeatingExistingVotes PASS (Late-route backfill, not repair of already-advanced omission.); TestILNDiscoveryRetryOnTransientRegistryFailure PASS (Explicit-error retry; successful omission is distinct.)

Production/release limit. Published v3.3.8 download digest and embedded VCS revision match the frozen source. Actual installed validator binary hashes remain unverified. No new omitted-log adversarial test or live provider manipulation. Primary historical procedure/evidence ZIP unavailable. Current residual maps to F-21.

2026-10-25 / N-05 - Two-hop sponsorship can deadlock before the final-destination gas grant exists

Historical: High. Current: Resolved original circular stage dependency. Disposition: VERIFIED.

Original condition and boundary. The zero-native-balance two-hop journey required progress toward TX3 before a later grant became payable, while that progress itself required the destination gas whose grant had not yet been issued. The second-hop message/stage dependency created a circular liveness prerequisite. A valid paid two-hop source quote promises gas, the wallet lacks the required downstream native gas, and the service follows its original stage-dependent grant schedule. No compromised actor is necessary.

Current assessment. All immutable positive quote grants are selected and authenticated from finalized TX1. The first-delivery, hub-onward and final-delivery stages do not require child operation records, TX2 delivery or TX3 execution. The normal wallet path requires confirmed upfront grants before TX2, while an exactly matched immutable zero-grant quote is allowed to continue without waiting for the sponsor.

Source anchors. `services/managed-relay/gas-sponsor.mjs:25-40`; `services/managed-relay/gas-sponsor.mjs:61-78`; `services/managed-relay/gas-sponsor.mjs:100-134`; `services/managed-relay/gas-sponsor.mjs:451-470`; `apps/web/app.js:530-567`; `apps/web/transfer-sponsor-evidence.js:6-25`.

Correction history. xgr-interchain PR309, merge `ab6d98395824beb71733577b0f49b2d167ab2761` (Initial parent-authenticated final-delivery promise at continuation; later superseded by the fully upfront schedule.); xgr-interchain PR311, merge `f65cdf89b55953778e2c5c6a50f341d22d3b7052` (All original signed grants become due immediately after independently verified TX1; wallet continuation gates on those grants.).

Independent checks. Executed the exact candidate SQL extracted from frozen runSponsorSweep against the actual PostgreSQL engine and current schemas. One paid two-hop parent with three immutable commitments and zero child operations yields all three grant stages immediately. Stage-eligibility, immutable quote binding, grant tampering and reserve-before-payment tests pass in the 92-test managed-relay suite. 3/3 wallet evidence tests pass: paid fees alone do not imply grants, positive promises remain gated, and only exact immutable zero-grant evidence permits ungated continuation.

Production/release limit. No paid empty-gas one-hop or two-hop production journey was executed. Live sponsor availability was false. Source closure of N-05 therefore does not establish commercial end-to-end readiness. The old circular dependency is removed. A distinct boundary remains: an external permissionless TX2 completion before all grants are issued makes later grants ineligible because the parent must remain undelivered. The ordinary UI prevents this sequence, but other clients can perform it. S-A02 nonce stranding and S-A03 cross-chain RPC aborts are also separate service-availability findings; they do not recreate the original child-message prerequisite.

2026-10-25 / N-06 - Unpaid public quotes can consume the rolling daily sponsor budget

Historical: Medium. Current: Medium. Disposition: OPEN.

Original condition and boundary. An unauthenticated public caller can obtain unused signed quotes whose positive gas commitments consume the finite sponsor budget even though no source fee is paid. Honest quotes then fail capacity admission. Sponsorship and positive quote issuance are enabled and sufficiently funded. Enough valid requests with native deficits are admitted to consume the available commitment budget; cheap replacement payer addresses and, if needed, multiple client IPs satisfy the bounded per-identity limits. The attacker does not need to broadcast TX1 or receive the gas grant.

Current assessment. The holding period is materially reduced, but the original public-reservation resource-exhaustion mechanism remains. Quote admission still records an unpaid positive promise and charges spentToday plus all unsettled promises to daily capacity. Request throttles allow four attempts per IP, two per payer and 120 globally per minute. The caller supplies a payer address without proving control or paying a reservation cost. Repeated admitted requests can keep a finite budget occupied; this is a conditional capacity attack, not a claim that every treasury or gas-price configuration is saturable from one IP.

Source anchors. `services/managed-relay/server.mjs:339-360`; `services/managed-relay/server.mjs:441-461`; `services/managed-relay/tax-evidence.mjs:125-175`; `services/managed-relay/sponsor-funding.mjs:42-52`; `services/managed-relay/gas-sponsor.mjs:393-434`; `services/managed-relay/sponsor-policy.mjs:11-13`.

Correction history. xgr-interchain PR330, merge `54ec66f59070b342ba07d4d0a17a274ace5cc399` (Partial mitigation: release only expired unused quote liabilities after a finalized source nonce observation; executed or ambiguous obligations remain reserved.); xgr-interchain PR331, merge `fdfd342671936fa7c74fc18be5e60ef8679f61c0` (Partial mitigation: lower the expiry selection grace from ten to five minutes; signed source execution lifetime remains 90 seconds.).

Independent checks. The rate-limiter test passes. The expiry regression checks the five-minute SQL threshold and confirms unavailable finality evidence causes no release. It does not simulate adversarial continuous quote saturation. A separate actual expiry-function test confirms one finalized-head response plus a number-tagged nonce call can append a resolution without an independent witness or post-call hash recheck. This is a separate trust/release caveat, not the unpaid-reservation DoS reproduction.

Production/release limit. The deployed positive-quote permission path, treasury levels and achievable saturation rate were not measured. The read-only sponsor readiness state was already unavailable, so this audit cannot attribute live unavailability to N-06. Time alone no longer authorizes release, and an honest unavailable nonce observation retains the obligation. Used quotes are not reclassified as unused. Those are valuable protections against underfunding but do not authenticate demand or prevent budget occupation. The five-minute selection threshold is not a guaranteed release time: source finalized-state age, worker cadence and the bounded 80-row reconciliation queue can extend it. The receipt-free admission path and budget arithmetic establish the remaining mechanism statically; no live rate-limit exhaustion was attempted. Current residual maps to F-17.

2026-10-25 / N-07 - Sponsor admission does not reserve aggregate spendable treasury against outstanding promises

Historical: Medium. Current: Resolved original aggregate-accounting condition. Disposition: VERIFIED.

Original condition and boundary. New signed quotes could each pass a per-quote or stale funding check without accounting for all outstanding promises, allowing aggregate signed obligations to exceed the spendable sponsor treasury. Multiple valid sponsored quotes arrive while finite native funds are shared across their promised stages. Concurrent admission increases exposure; malicious private keys or principal-authentication bypass are unnecessary.

Current assessment. Positive quote commitments are appended within one transaction after sorted per-chain advisory locks. Under each lock the code counts every unsettled promise except a proven expired-unused quote or a confirmed grant, reads current wallet balance and gas price, includes a bounded payout-gas reserve for every outstanding and new grant, and enforces both liquidity and daily capacity. Any failure rolls the whole quote transaction back before the HTTP response exposes its signature.

Source anchors. `services/managed-relay/tax-evidence.mjs:118-180`; `services/managed-relay/sponsor-funding.mjs:21-53`; `services/managed-relay/server.mjs:453-463`; `services/managed-relay/gas-sponsor.mjs:280-303`.

Correction history. xgr-interchain PR330, merge `54ec66f59070b342ba07d4d0a17a274ace5cc399` (Aggregate outstanding-liability, fresh-funding and payout-gas accounting under the common per-chain advisory lock.).

Independent checks. Pure aggregate-capacity tests and actual saveQuoteEvidence calls with a fake pool verify rejection of insufficient funds/budget, one atomic commit for all grants, rollback and nonce/fee binding. These tests passed within 92/92 managed-relay tests. An actual PostgreSQL-engine run applied the exact migrations and exercised actual saveQuoteEvidence under the documented dedicated writer role. It exposed S-A01: the newly required operations-table SELECT is missing although health readiness checks pass; the permission failure rolls back all rows. This is a separate availability/permission integration defect, not permission to overcommit.

Production/release limit. S-A01 blocks a documented dedicated-role installation until grants/readiness are corrected; a consolidated worker role may already possess the needed SELECT. The actual deployed role and live concurrency behavior were not inspected. VERIFIED is limited to original source-level accounting and executed local checks, not production reserve assurance. The original omission of aggregate liabilities is closed in code. Multi-process lock scheduling was reviewed, not stress-tested against separate PostgreSQL sessions. Treasury funds are observed, not escrowed: independent withdrawals, unreliable RPC evidence or future price changes remain operational assumptions. Unconfirmed grants are conservatively counted in both outstanding liabilities and spentToday, which can reduce availability without creating the old undercount. A false single-RPC unused resolution could release a real obligation; that trust caveat is recorded separately.

2026-10-25 / N-08 - Outgoing gas-gift receipts can become permanently confirmed before the adopted native-chain finality threshold

Historical: Medium. Current: Resolved original premature-confirmation condition. Disposition: VERIFIED.

Original condition and boundary. The worker could treat the first successful native-gift receipt as final and permanently close the one-shot grant, even while the payment remained above the adopted safe/committed native-chain threshold. A sponsor payout is initially mined successfully, then reorganized or inconsistently reported before the adopted native finality threshold. The original durable confirmed state suppresses a legitimate later payment/recovery path.

Current assessment. Both immediate receipt handling and submitted-grant reconciliation invoke verifiedSponsorFinality before recording confirmed. The helper requires a successful matching receipt, a native head covering the receipt, matching canonical receipt block hashes and a freshly observed successful receipt. Base/Arbitrum use safe; XGRChain uses latest with two additional blocks. Unsupported or insufficient evidence retains submitted status and does not authorize duplicate payment.

Source anchors. `services/managed-relay/gas-sponsor.mjs:136-158`; `services/managed-relay/gas-sponsor.mjs:227-240`; `services/managed-relay/gas-sponsor.mjs:340-360`.

Correction history. xgr-interchain PR330, merge `54ec66f59070b342ba07d4d0a17a274ace5cc399` (Safe/canonical native payout confirmation used on the initial path and restart reconciliation.).

Independent checks. The actual finality-helper regression passes: Base receipt block 100 is held at safe 99 and accepted at safe 100; XGRChain requires latest at least 102 for block 100; unsupported safe RPC is held. The equality checks for canonical block and refreshed receipt hashes were additionally inspected in both call paths. No real reorganization or live payout was generated.

Production/release limit. Runtime support for required tags was not established through a real outgoing gift. The installed worker and production recovery journal were not read; no RELEASED conclusion is warranted. The old one-confirmation shortcut is removed. Consistently dishonest RPC data can still satisfy a single-provider check, and safe means the adopted native threshold rather than arbitrary stronger finality. Reserved/needs-review rows without a recorded transaction hash are not reconciled; that distinct crash-recovery gap is S-A02. One submitted-row RPC exception can abort the whole sweep; that distinct availability defect is S-A03.

2026-10-25 / N-09 - UI can present deferred native principal as completed payout without a claim action

Historical: Medium. Current: Medium. Disposition: OPEN.

Original condition and boundary. The native router deliberately treats a fully reserved deferred payout as successful message handling. Presentation equates final Mailbox handling with beneficiary balance receipt, and does not discover or expose the beneficiary-only withdrawal. Authenticated inbound native XGR transfer to a recipient whose receive/fallback rejects or exceeds the bounded payout gas. No malicious BLS signer or transport replay is needed.

Current assessment. The native router deliberately treats a fully reserved deferred payout as successful message handling. Presentation equates final Mailbox handling with beneficiary balance receipt, and does not discover or expose the beneficiary-only withdrawal. A user can see an apparently completed principal payout while value remains in router custody and requires a claim. A general smart wallet can call the claim function itself or direct payout to another address; a contract with no arbitrary-call or claim facility may be unable to recover. External ownership of a contract does not authorize an EOA to claim its balance.

Source anchors. `contracts/XETAGuardedNativeWarpRouter.sol:12-38,68-85`; `services/indexer/transfer-index.mjs:62-71,97-115`; `services/indexer/transfer-index-store.mjs:47-57`; `apps/web/transfer-status-flow.js:25-26,119-126`; `apps/web/transfer-token-journey.js:10-19,63-85`.

Correction history. xgr-interchain PR328, merge `dcf73448e0e190ade818c8c92de385323a3afeec` (Adds compact token journey labels; no claim-state recovery.); xgr-interchain PR332, merge `4b8541b804a3e59608695ff371b54f86a1d22ba1` (Status/balance-refresh changes do not turn a reserved claim into principal receipt.); xgr-interchain PR334, merge `b22e285a1fa8378bf14edc996b342dcaa15249a7` (Latest status modal refinements still mark the delivered path complete without pending-claim discovery.).

Independent checks. Real Mailbox and native router with explicitly mocked accepting ISM: delivered=true, recipient balance unchanged, claim fully backed, replay rejected, original beneficiary claims to alternate recipient, no residual debt. The actual UI projection reports: "Transfer complete", "no further wallet action", "native unlock step complete", and the summary "XGR unlocked on XGRChain. Delivery verified." These displayed claims do not establish beneficiary balance availability. No claim about a named third-party wallet's exact implementation; local composition is not a browser end-to-end or production transaction. BLS verification is mocked only for this payout test and covered separately in cryptographic tests.

Production/release limit. Current deployed code and configuration are independently checked in this audit; no future deployment, real reorganization, production journal crash or compiler equivalence is implied. Current residual maps to F-09.

2026-10-25 / N-10 - Known provisional source transfers disappear from displayed history after wallet reconnection

Historical: Low. Current: Resolved original condition with bounded local retention. Disposition: VERIFIED.

Original condition and boundary. A wallet broadcast locator was lost on reconnect/reload before durable indexed discovery became available. A broadcast has not yet been independently indexed; wallet/session reconnects.

Current assessment. Public transaction hints are saved per wallet, restored on reconnect and shown separately from canonically verified pending journeys. Invalid/stale hints do not authorize actions. Retention is bounded to 32 hints and 365 days; cross-device recovery depends on canonical index or a known hash, not browser local storage.

Source anchors. `apps/web/source-tx-hints.js:1-76`; `apps/web/app.js:20,272,359-369`; `apps/web/wallet-index-projection.js`.

Correction history. xgr-interchain PR319, merge `b098e9eb54213fef16cdbd4e1ca711669185a567`; xgr-interchain PR321, merge `8af4ae639f5b75a69fbd823b0693cdcdd6ef1397`.

Independent checks. source-tx-hints3/3; wallet projection5/5 and related pending/recovery tests passed. Browser smoke tests could not run without Chromium; no real wallet reconnect acceptance test.

Production/release limit. Public app.js matches frozen source; all module/runtime combinations not attested.

2026-10-25 / N-11 - Retired or unknown-route rows indefinitely starve delivery refresh

Historical: Medium. Current: Medium. Disposition: OPEN.

Original condition and boundary. Rows lacking an active route occupy the oldest bounded delivery worklist and are skipped without changing their scheduling position. Sufficient historical retired/unknown-route rows remain at the front of the derived SQL worklist. This is a backlog condition, not arbitrary direct database access for public users.

Current assessment. PR310 explicitly remediates only wallet pagination. The independent refreshPendingDeliveries query still selects all routes before resolving them and immediately continues for unknown routes before its attempt timestamp update. A real PostgreSQL-engine run using current migrations reproduced repeated selection without any active-route RPC read. Wallet ordering and background delivery scheduling are separate paths.

Source anchors. `services/indexer/transfer-index-worker.mjs:197-225`; `services/indexer/transfer-index-store.mjs:118-148`.

Correction history. xgr-interchain PR310, merge `f353d540519da2a373cd31e86b9a61e1d01cdafb` (Partial: wallet API worklist only. PR body expressly says partial scope.).

Independent checks. Existing wallet query-order regression passed. New actual-SQL refresh starvation regression also passed by reproducing the still-open worker behavior (PGlite 0.5.12, exact source schema/function). No production database access or concurrency stress.

Production/release limit. No actual current retired backlog was inspected; live route index reports caught up. Current residual maps to F-26.

2026-10-25 / N-12 - Positive microfees make transfers without sponsorship promises eligible to starve owed grants

Historical: Medium. Current: Resolved original no-promise candidate poisoning condition. Disposition: VERIFIED.

Original condition and boundary. Older operations with any positive service fee could occupy the limited sponsor candidate worklist even though no immutable gas promise existed. Rejected no-promise rows stayed ahead of later payable grants and could repeatedly consume the candidate window. Enough older valid positive-fee operations without gas commitments precede a genuine owed sponsored transfer. Creating those source operations can have a cost; arbitrary public writes to the database are not assumed.

Current assessment. The current candidate query inner-joins the exact payer/source/adapter/quote nonce/fee intent and its immutable commitment rows before ORDER BY and LIMIT 120. No-promise positive-fee transfers cannot consume that candidate window. Grant execution independently verifies the matching finalized source receipt and immutable promise.

Source anchors. `services/managed-relay/gas-sponsor.mjs:451-470`; `services/managed-relay/gas-sponsor.mjs:61-78`; `services/managed-relay/gas-sponsor.mjs:100-116`.

Correction history. xgr-interchain PR311, merge `f65cdf89b55953778e2c5c6a50f341d22d3b7052` (The immutable-commitment-driven upfront selection also closes this original worklist-poisoning condition, though the PR title focuses on the commercial upfront flow. Attribution is based on the verified candidate-query diff.).

Independent checks. Applied the current schemas to the actual PostgreSQL engine, inserted 125 older positive-fee operations without promises and one later paid two-hop parent with three promises, and executed the exact frozen candidate SQL. All 125 no-promise operations are excluded; the only selected rows are final-delivery/arbitrum, first-delivery/xgrchain and hub-onward/xgrchain for the owed transfer.

Production/release limit. The exact SQL behavior is locally verified, but no production workload, backlog or installed worker was inspected. This test is not a throughput or concurrent-session test. The original positive-microfee/no-promise poison rows no longer reach the bounded window. Other kinds of unresolved promised rows, reserved nonce locks or submitted-row RPC failures can still reduce sponsor availability; these are separate conditions and must not be conflated with proof that N-12 remains open.

12. Launch decision and remediation gates

Decision: NO-GO. This applies to the frozen source and the observed deployment state, with later source changes expressly outside scope. It is a security/operational assessment, not a deployment action or permission to alter production.

P0 - Resolve before any public launch approval

F-01 must be resolved with a defensible system-transaction admissibility and accounting model, targeted rejection/supply-conservation tests, the exact corrected published release and independently verified installed validator digests. If an intended consensus rule makes the observed local path unreachable, that exclusion must be demonstrated through the actual block-validation boundary rather than asserted from mempool behavior. The completed local observations and source trace remain sufficient to withhold approval while that question is open.

P1 - Controlled operation and scaling requirements

After P0 closure, a controlled launch could be reassessed only with documented operational restrictions and current evidence. Establish installed signer identity, provider/fallback diversity, current quorum availability and agreed L2 safe assumptions. Resolve or explicitly bound resource/submission RPC exposure, durable recovery loss, discovery completeness, retry and delivery-queue fairness. Prove the supported native-recipient claim path or restrict the product's supported recipient model with accurate disclosure.

For a sponsored launch, correct restricted-role readiness and durable grant lifecycle/reconciliation; demonstrate availability, sufficiently backed promises and interruption recovery with representative low-gas one- and two-hop journeys. Otherwise the product must honestly expose self-funded operation and manage existing paid obligations; simply disabling a service is not closure of already promised grants. Do not introduce central custody or arbitrary route admission as a convenience fix.

F-22 must be corrected before further deployment/catalog promotion, despite its current backlog priority P2. Minimum committee size and independent operation must be monitored. P1 items may support a limited, explicitly accepted operating mode; they do not confer approval while P0 remains open.

P2 - Strengthening and maintenance

Close exact wallet calldata-intent binding, owner/service transition invariants, regression/CI drift, conservative double accounting, admin lock recovery, fee-tax backfill, adaptive dense-event processing, release CLI metadata and targeted compiler applicability work. Each change needs focused verification that addresses its actual boundary, not broad repetitive test execution or a claim based solely on a merged PR.

Evidence required for an unconditional approval

An unconditional approval requires closed P0 issues, verified or explicitly accepted and operationally bounded material P1 risks, installed-software identity, current deployment bindings, successful representative wallet journeys, recoverable commitments and exercised failure/restart procedures. The baseline architecture assumptions must be documented with responsible acceptance and monitoring. Low/Informational maintenance may remain only where it does not invalidate those claims. No amount of report archival alone closes a security finding.

Existing accepted risk is limited to the historical single-active-registry decision and explicitly documented token/finality architecture constraints. This audit does not invent a new acceptance of H-01, missing production evidence or the node accounting issue on the owner's behalf.

13. Artifact integrity and archival

The versioned directory contains the original newly authored English `report.pdf`, complete `report.md`, the unchanged Phase-A record and freeze manifest, current `findings.csv`, the full historical matrix, verification and remediation registers, a public evidence inventory and actual ZIP, and an exact-byte archive manifest. Report and PDF are content-equivalent presentations; neither is a placeholder or a filename-only promise.

Confidential current evidence was actually saved in access-controlled persistent storage under reference `libfile_b50f042ceb0c8191a9e8d0bf027b152c`. Archive `XITA_2026-10-27_Confidential_Evidence.zip`: **62218 bytes**, **38 entries**, SHA-256 **c957de67af58ada37db103da545fcdf98d46b99b02ddefe7a0376845d7d45c32**. This opaque reference is for the audit owner; it is not a public download link. The record preserves the distinction between executed local checks and an unexecuted scenario. The private archive does not replace the mandatory public GitHub PDF/ZIP publication.

The public archive excludes private keys, customer records, private operational secrets and executable reproductions for unrepaired vulnerabilities. Synthetic public test summaries and read-only chain/deployment records are included only at a safe disclosure level. The original source trees are identified by exact Git object hashes rather than duplicated dependency/source archives.

`archive-manifest.json` records filenames, bytes, SHA-256 and source revisions. Its own hash is necessarily external to its self-referential list and is supplied in the final repository verification record. The publication process requires actual binary blob upload, a dedicated documentation PR, merge to main and exact-byte readback of every manifested artifact from main. Until that readback succeeds, archival is pending; source conclusions do not depend on prematurely claiming COMPLETED. The final delivery identifies the immutable archive commit, PR and verified hashes.

No application, node or contract source change, deployment, transaction or production configuration mutation is part of this audit publication.